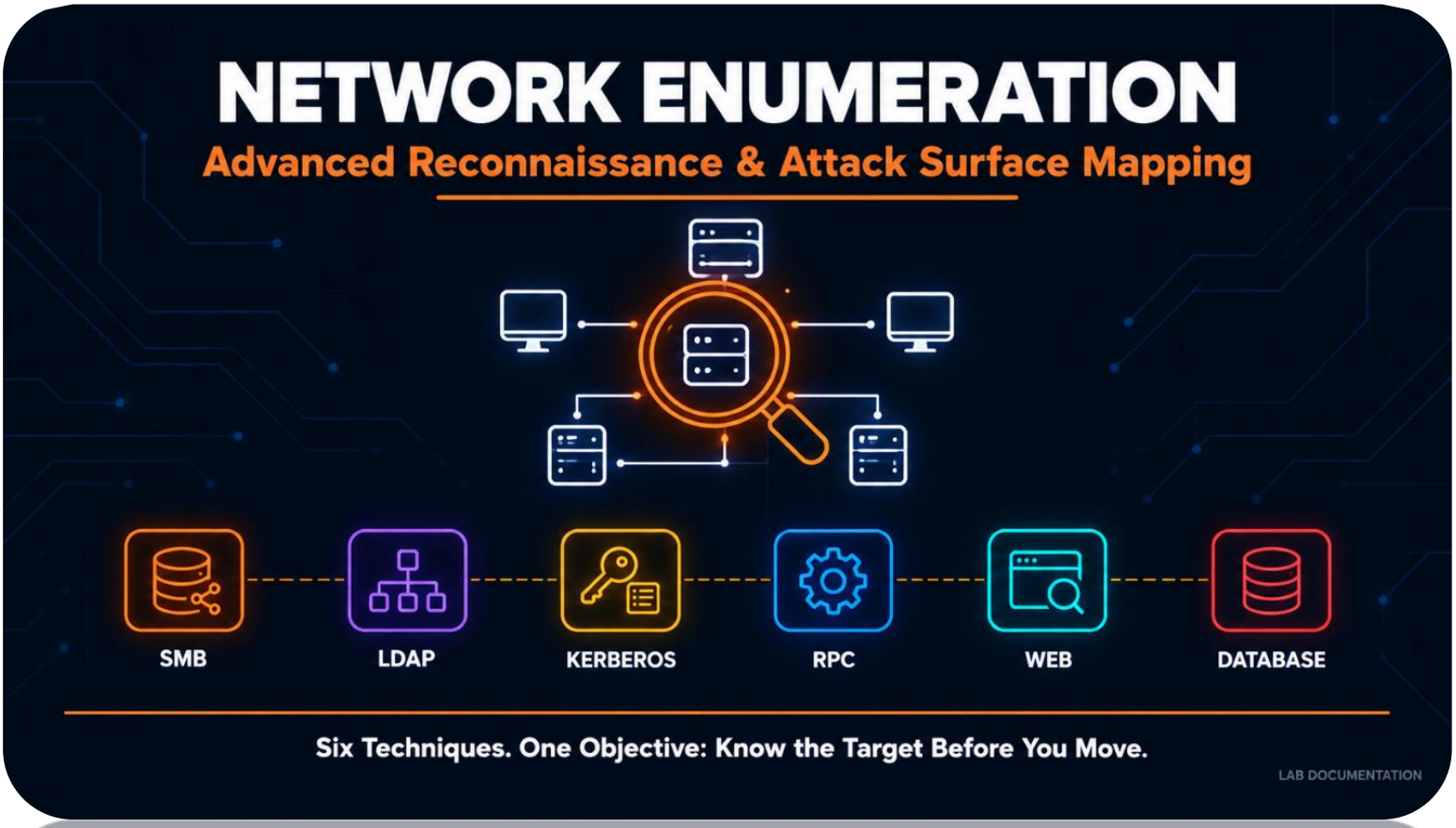


Prepared by: ***Abdul Wahid***
Document Type: ***Lab Report***
Category: ***Network Enumeration & Reconnaissance***

Contents

SMB/CIFS Deep Enumeration 5

Test Null Session Connectivity 7

Perform Comprehensive SMB Enumeration 8

Use CrackMapExec for Rapid Multi-Target Enumeration 12

LDAP/Active Directory Deep Enumeration 14

Extract Domain Information Using ldapsearch 17

GUI-Based Enumeration Using AD Explorer 18

Launch AD Explorer and Connect to the Domain Controller 20

Kerberos User Enumeration (kerbrute) 24

Install kerbrute (If Not Present) 25

Prepare Usernames Wordlist 26

Enumerate Users Using kerbrute 26

RPC/DCOM Enumeration 27

Verify RPC Service Is Running 28

Install Impacket rpcdump (If Needed) 28

Enumerate RPC Endpoints — Windows 10 29

Enumerate RPC Endpoints — Windows Server 2025 (Domain Controller) 31

Web Service Enumeration 34

Identify Active Web Services 35

Fingerprint the Web Server 35

Technology Fingerprinting 36

Directory Brute-Forcing (Gobuster) 37

High-Speed Fuzzing (ffuf) 38

Vulnerability Scanning (Nikto) 38

API Endpoint Enumeration 39

Database Service Enumeration 40

Identify Database Services 41

Enumerate MySQL 41

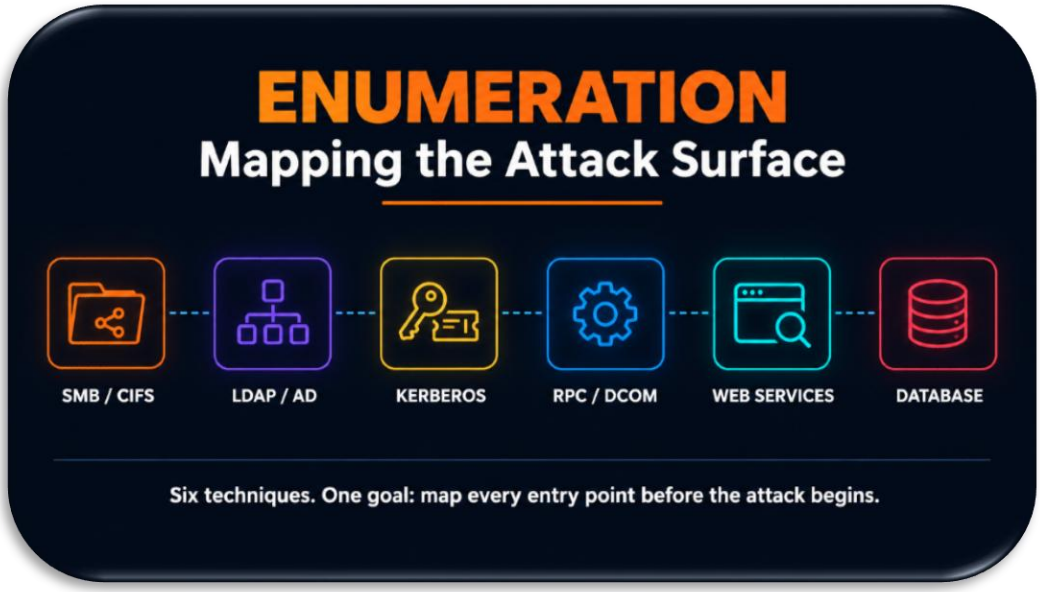
Offline Hash Cracking 43

Conclusion 44

Executive Summary

This engagement was conducted entirely within an isolated VirtualBox host-only network (192.168.100.0/24) with no internet connectivity, ensuring all scanning, enumeration, and reconnaissance activity was performed safely and without legal or ethical exposure. The lab comprised four systems: a Kali Linux attack platform, a Metasploitable 2 Linux target, a DVWA web application target (Docker-hosted), and a Windows 10 client — later expanded to include a Windows Server 2025 Domain Controller for directory-service and enterprise-focused testing.

Objective: To build hands-on proficiency in advanced network enumeration methodologies by systematically identifying, mapping, and documenting the attack surface of both a deliberately vulnerable Linux/web target and a more representative, hardened Windows enterprise environment — without relying on prior credentials.



Scope of Work Completed: Six enumeration techniques were executed and documented to completion, covering network file-sharing services, directory services, authentication mechanisms, Windows service interfaces, the web application layer, and database services:

Technique	Focus Area
#1	SMB/CIFS Deep Enumeration
#2	LDAP/Active Directory Enumeration
#3	Kerberos User Enumeration
#4	RPC/DCOM Enumeration
#5	Web Service Enumeration
#6	Database Service Enumeration

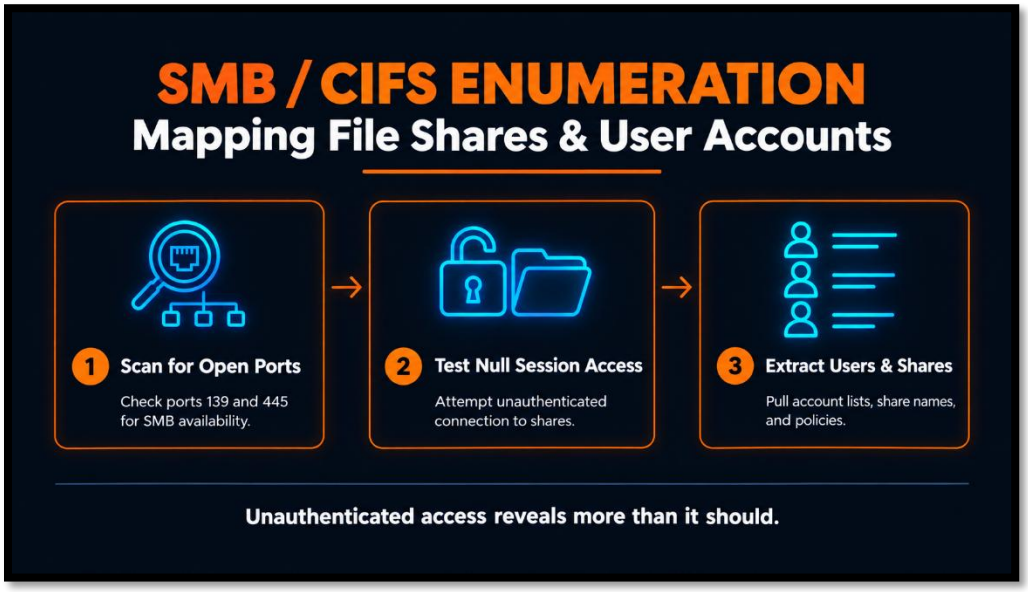
Key Findings: The exercise produced a clear, real-world contrast between a hardened system and an intentionally vulnerable one. Metasploitable 2 was found to be broadly exploitable — permitting null SMB sessions that exposed 35+ user accounts, unauthenticated root-level MySQL access that yielded application credentials, and an outdated, unpatched web stack with exposed administrative interfaces (phpMyAdmin, phpinfo).

By contrast, the Windows 10 and Windows Server 2025 systems correctly blocked unauthenticated SMB access, reflecting modern default hardening; however, both still exposed a meaningful RPC service surface (351–527 endpoints, including SAM and DRSUAPI interfaces), and the Domain Controller's LDAP and Kerberos services were enumerable without credentials — information that, in a real engagement, would directly inform credential-based attacks such as Kerberoasting, AS-REP roasting, and credential spraying.

SMB/CIFS Deep Enumeration

Overview

SMB/CIFS (ports 139/445) allows Windows systems to share files and resources over a network, making it one of the highest-value services to target early in an internal engagement. This exercise performs deep enumeration across three lab hosts — extracting shares, users, groups, domain information, and security policies — without credentials, via null session exploitation.



Targets:

Role	System	IP Address
Attacker	Kali Linux	192.168.100.140
Target 1	Windows 10	192.168.100.147
Target 2	Windows Server 2025	192.168.100.150
Target 3	Metasploitable 2	192.168.100.148

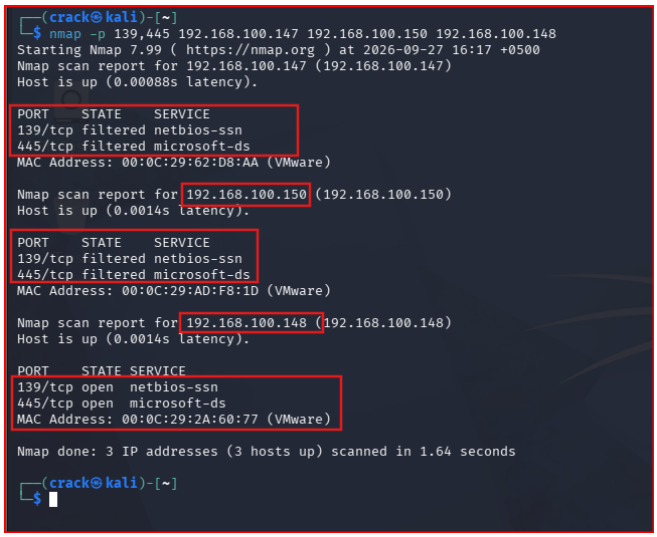
Tools: enum4linux (deep SMB enumeration), smbclient (null session testing), crackmapexec (multi-target validation)

Risk profile: Medium detection risk — SMB queries are logged by IDS/SIEM — but require no authentication to attempt.

Verify SMB Service Is Running

Objective: Confirm SMB ports (139/445) are open on all target systems before attempting enumeration.

```
nmap -p 139,445 192.168.100.147 192.168.100.150 192.168.100.148
```



What This Means:

- Port 139: NetBIOS-SSN (legacy SMB over NetBIOS)
- Port 445: Microsoft-DS (native SMB over direct TCP)
- If both are open → SMB is accessible and worth pursuing further

Finding: Confirms which of the three targets expose SMB before spending time on null-session and enumeration attempts against hosts that don't even have the service reachable.

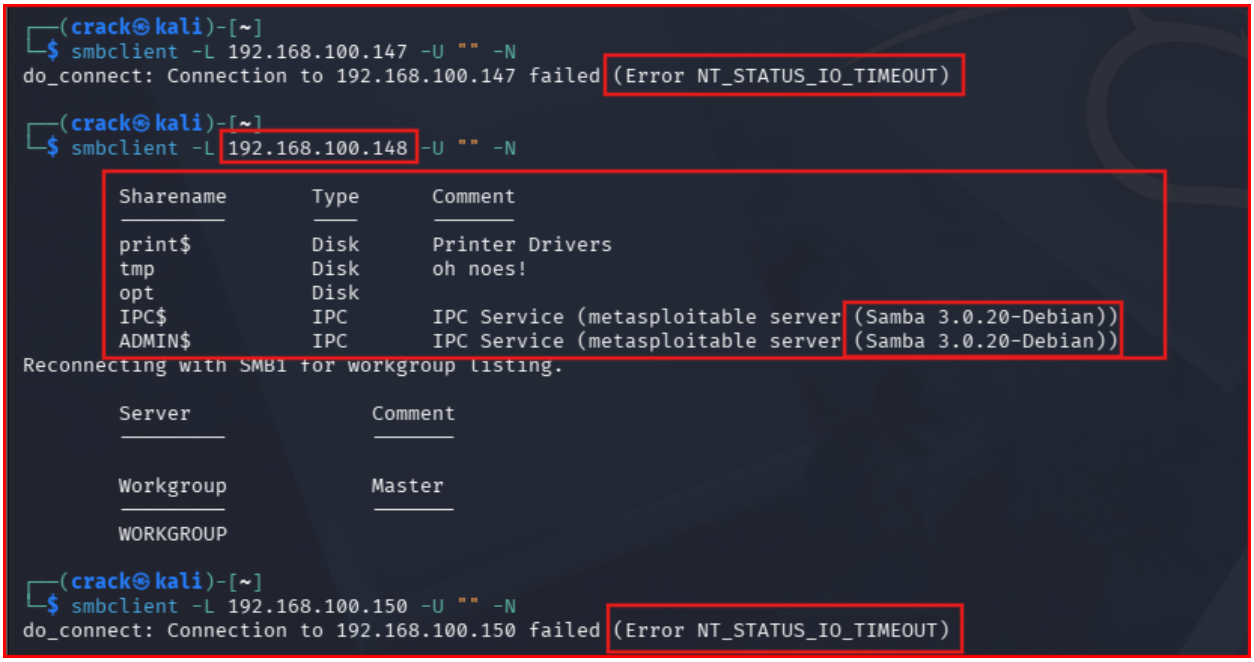
Test Null Session Connectivity

Objective: Verify whether unauthenticated (null) SMB sessions are possible on each target.

```
smbclient -L 192.168.100.147 -U "" -N     # Windows 10

smbclient -L 192.168.100.150 -U "" -N     # Windows Server 2025

smbclient -L 192.168.100.148 -U "" -N     # Metasploitable 2
```



How this works:

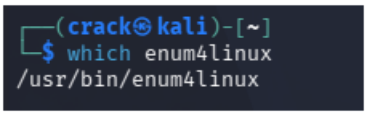
1. smbclient opens a TCP connection to the target on port 445 (preferred) or 139
2. Sends an SMB Negotiate Protocol request
3. Sends a Session Setup request with empty credentials (null session)
4. If the server allows null sessions, it accepts the connection and lists shares (-L)
5. If hardened (default on modern Windows 10 / Server 2025), it rejects the session with NT_STATUS_ACCESS_DENIED

Finding: This is effectively a targeted, unauthenticated login attempt against each host — the result directly predicts whether deep enumeration (Step 4) will succeed or fail on that specific target.

Install enum4linux (If Not Present)

Objective: Prepare the primary comprehensive SMB enumeration tool.

```
which enum4linux
```

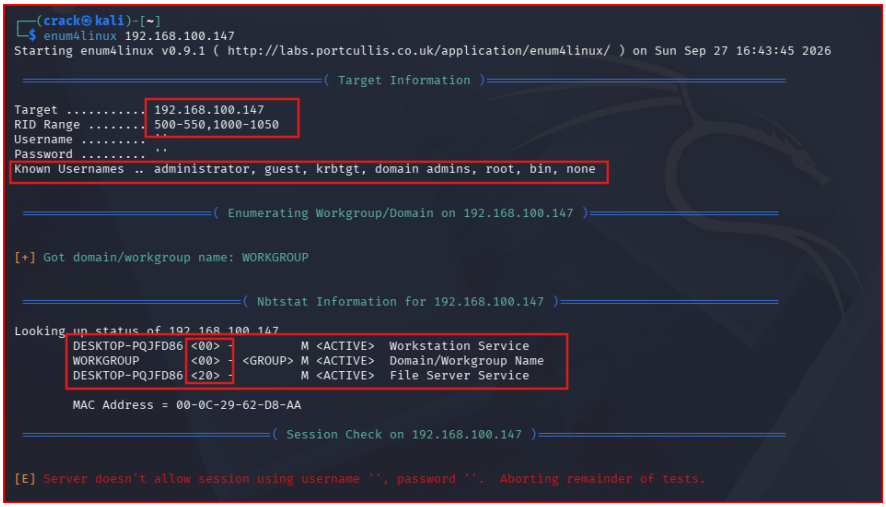


Finding: Straightforward environment preparation step — confirms the tool is available before it's relied on in Step 4.

Perform Comprehensive SMB Enumeration

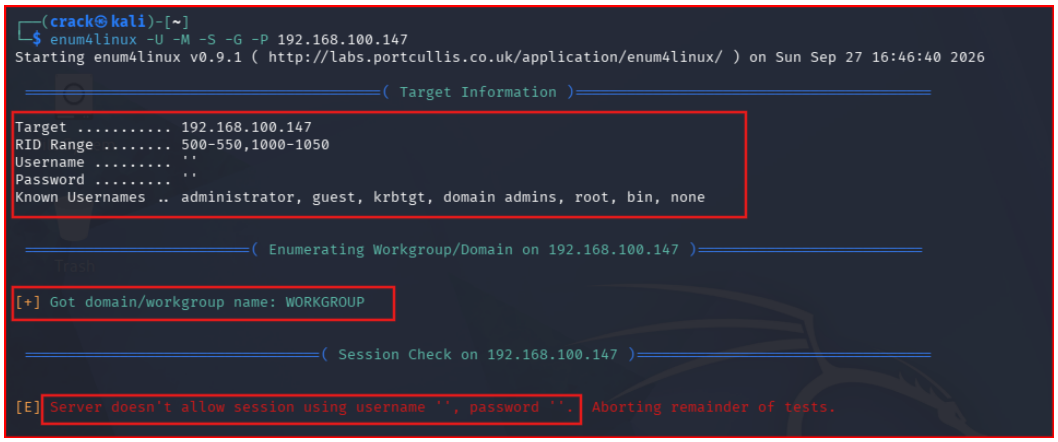
4A. Basic Enumeration — Windows 10

```
enum4linux 192.168.100.147
```



4B. Detailed Enumeration with Specific Queries — Windows 10

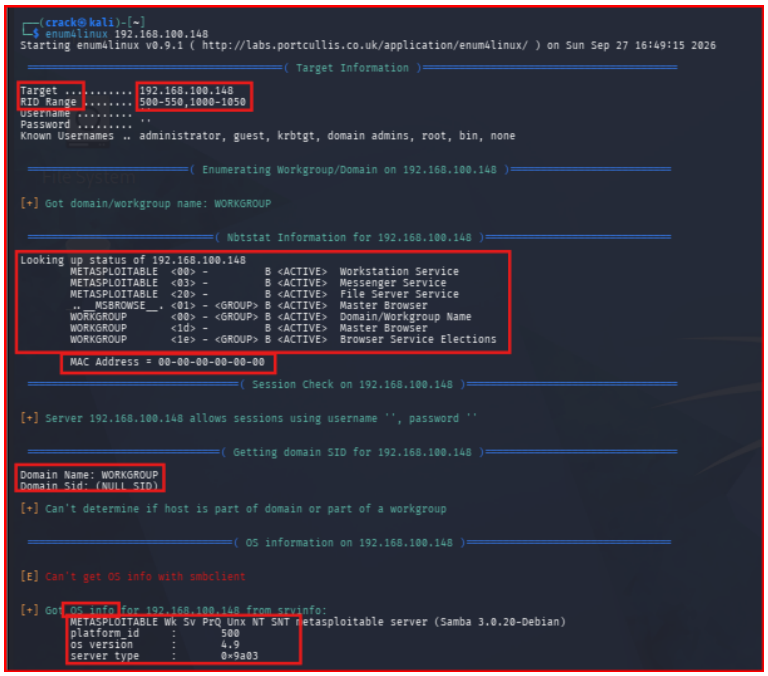
`enum4linux [additional targeted flags] 192.168.100.147`

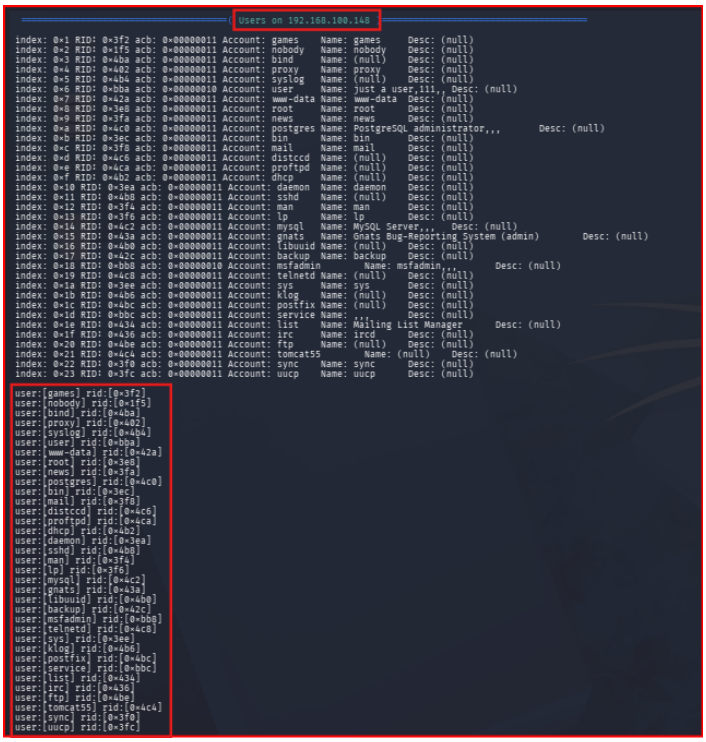


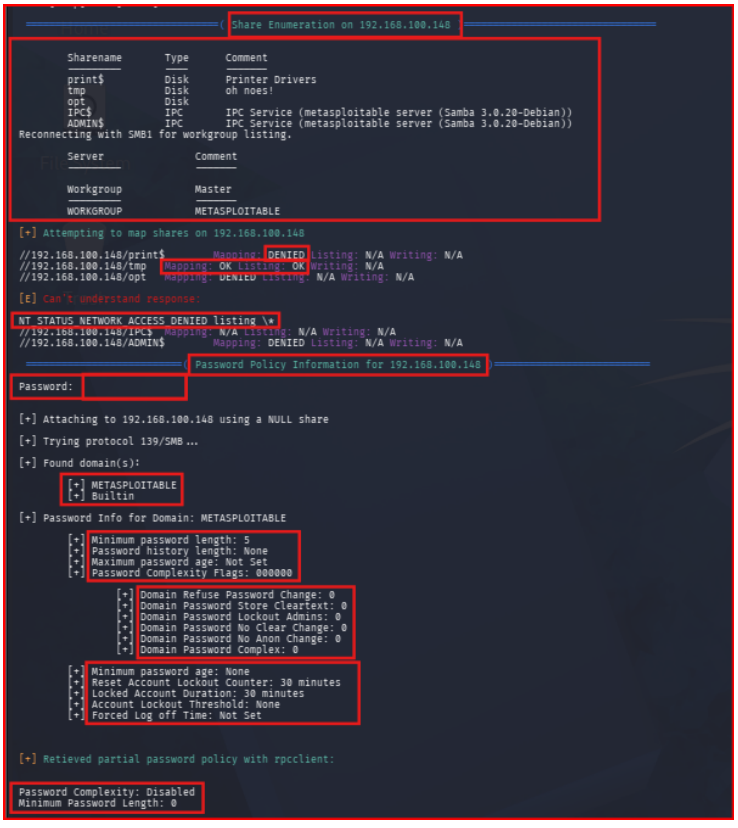
Finding (4A + 4B combined): Null session enumeration **failed** — the target does not allow unauthenticated SMB sessions (Server doesn't allow session using username '', password ‘). Only basic information was retrieved: workgroup **WORKGROUP** and hostname **DESKTOP-PQJFD86**. Deep enumeration (users, shares, groups) was not possible due to security hardening.

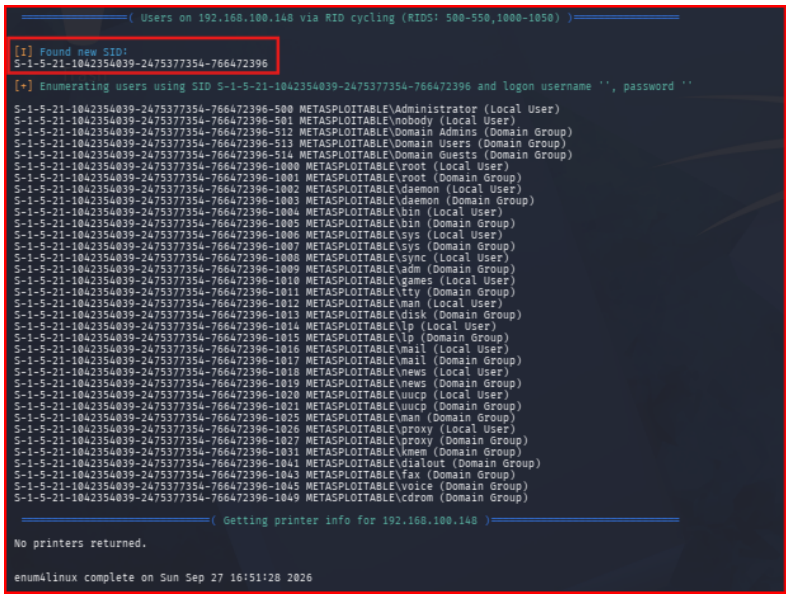
4C. Enumeration — Metasploitable 2

`enum4linux 192.168.100.148`




Users on 192.168.100.148
index: 0x1 RID: 0x3f2 acb: 0x00000011 Account: games Name: games Desc: (null)
index: 0x2 RID: 0x1f5 acb: 0x00000011 Account: nobody Name: nobody Desc: (null)
index: 0x3 RID: 0x4ba acb: 0x00000011 Account: bind Name: (null) Desc: (null)
index: 0x4 RID: 0x402 acb: 0x00000011 Account: proxy Name: proxy Desc: (null)
index: 0x5 RID: 0x4b4 acb: 0x00000011 Account: syslog Name: (null) Desc: (null)
index: 0x6 RID: 0x4bb acb: 0x00000010 Account: user Name: just a user,111,, Desc: (null)
index: 0x7 RID: 0x42a acb: 0x00000011 Account: www-data Name: www-data Desc: (null)
index: 0x8 RID: 0x3e8 acb: 0x00000011 Account: root Name: root Desc: (null)
index: 0x9 RID: 0x3fa acb: 0x00000011 Account: news Name: news Desc: (null)
index: 0xa RID: 0x4c0 acb: 0x00000011 Account: postgres Name: PostgreSQL administrator,,, Desc: (null)
index: 0xb RID: 0x3ec acb: 0x00000011 Account: bin Name: bin Desc: (null)
index: 0xc RID: 0x3f8 acb: 0x00000011 Account: mail Name: mail Desc: (null)
index: 0xd RID: 0x4c6 acb: 0x00000011 Account: distccd Name: (null) Desc: (null)
index: 0xe RID: 0x4ca acb: 0x00000011 Account: proftpd Name: (null) Desc: (null)
index: 0xf RID: 0x4b2 acb: 0x00000011 Account: dhcp Name: (null) Desc: (null)
index: 0x10 RID: 0x3ea acb: 0x00000011 Account: daemon Name: daemon Desc: (null)
index: 0x11 RID: 0x4b8 acb: 0x00000011 Account: sshd Name: (null) Desc: (null)
index: 0x12 RID: 0x3f4 acb: 0x00000011 Account: man Name: man Desc: (null)
index: 0x13 RID: 0x3f6 acb: 0x00000011 Account: lp Name: lp Desc: (null)
index: 0x14 RID: 0x4c2 acb: 0x00000011 Account: mysql Name: MySQL Server,,, Desc: (null)
index: 0x15 RID: 0x43a acb: 0x00000011 Account: gnats Name: Gnats Bug-Reporting System (admin) Desc: (null)
index: 0x16 RID: 0x4b0 acb: 0x00000011 Account: libuuid Name: (null) Desc: (null)
index: 0x17 RID: 0x42c acb: 0x00000011 Account: backup Name: backup Desc: (null)
index: 0x18 RID: 0xbb8 acb: 0x00000010 Account: msfadmin Name: msfadmin,,, Desc: (null)
index: 0x19 RID: 0x4c8 acb: 0x00000011 Account: telnetd Name: (null) Desc: (null)
index: 0x1a RID: 0x3ee acb: 0x00000011 Account: sys Name: sys Desc: (null)
index: 0x1b RID: 0x4b6 acb: 0x00000011 Account: klog Name: (null) Desc: (null)
index: 0x1c RID: 0x4bc acb: 0x00000011 Account: postfix Name: (null) Desc: (null)
index: 0x1d RID: 0x4bc acb: 0x00000011 Account: service Name: ,,, Desc: (null)
index: 0x1e RID: 0x434 acb: 0x00000011 Account: list Name: Mailing List Manager Desc: (null)
index: 0x1f RID: 0x436 acb: 0x00000011 Account: irc Name: ircd Desc: (null)
index: 0x20 RID: 0x4be acb: 0x00000011 Account: ftp Name: (null) Desc: (null)
index: 0x21 RID: 0x4c4 acb: 0x00000011 Account: tomcat55 Name: (null) Desc: (null)
index: 0x22 RID: 0x3f0 acb: 0x00000011 Account: sync Name: sync Desc: (null)
index: 0x23 RID: 0x3fc acb: 0x00000011 Account: uucp Name: uucp Desc: (null)
user:[games] rid:[0x3f2]
user:[nobody] rid:[0x1f5]
user:[bind] rid:[0x4ba]
user:[proxy] rid:[0x402]
user:[syslog] rid:[0x4b4]
user:[user] rid:[0x4bb]
user:[www-data] rid:[0x42a]
user:[root] rid:[0x3e8]
user:[news] rid:[0x3fa]
user:[postgres] rid:[0x4c0]
user:[bin] rid:[0x3ec]
user:[mail] rid:[0x3f8]
user:[distccd] rid:[0x4c6]
user:[proftpd] rid:[0x4ca]
user:[dhcp] rid:[0x4b2]
user:[daemon] rid:[0x3ea]
user:[sshd] rid:[0x4b8]
user:[man] rid:[0x3f4]
user:[lp] rid:[0x3f6]
user:[mysql] rid:[0x4c2]
user:[gnats] rid:[0x43a]
user:[libuuid] rid:[0x4b0]
user:[backup] rid:[0x42c]
user:[msfadmin] rid:[0xbb8]
user:[telnetd] rid:[0x4c8]
user:[sys] rid:[0x3ee]
user:[klog] rid:[0x4b6]
user:[postfix] rid:[0x4bc]
user:[service] rid:[0x4bc]
user:[list] rid:[0x434]
user:[irc] rid:[0x436]
user:[ftp] rid:[0x4be]
user:[tomcat55] rid:[0x4c4]
user:[sync] rid:[0x3f0]
user:[uucp] rid:[0x3fc]


Share Enumeration on 192.168.100.148
Sharename Type Comment
print$ Disk Printer Drivers
tmp Disk oh noes!
opt Disk
IPC$ IPC IPC Service (metasploitable server (Samba 3.0.20-Debian))
ADMIN$ IPC IPC Service (metasploitable server (Samba 3.0.20-Debian))
Reconnecting with SMB1 for workgroup listing.
Server Comment
Workgroup Master
WORKGROUP METASPLOITABLE
[+] Attempting to map shares on 192.168.100.148
//192.168.100.148/print$ Mapping: DENIED Listing: N/A Writing: N/A
//192.168.100.148/tmp Mapping: OK Listing: OK Writing: N/A
//192.168.100.148/opt Mapping: DENIED Listing: N/A Writing: N/A
[E] Can't understand response:
NT_STATUS_NETWORK_ACCESS_DENIED listing *
//192.168.100.148/IPC$ Mapping: N/A Listing: N/A Writing: N/A
//192.168.100.148/ADMIN$ Mapping: DENIED Listing: N/A Writing: N/A
Password Policy Information for 192.168.100.148
Password:
[+] Attaching to 192.168.100.148 using a NULL share
[+] Trying protocol 139/SMB ...
[+] Found domain(s):
[+] METASPLOITABLE
[+] Builtin
[+] Password Info for Domain: METASPLOITABLE
[+] Minimum password length: 5
[+] Password history length: None
[+] Maximum password age: Not Set
[+] Password Complexity Flags: 000000
[+] Domain Refuse Password Change: 0
[+] Domain Password Store Cleartext: 0
[+] Domain Password Lockout Admins: 0
[+] Domain Password No Clear Change: 0
[+] Domain Password No Anon Change: 0
[+] Domain Password Complex: 0
[+] Minimum password age: None
[+] Reset Account Lockout Counter: 30 minutes
[+] Locked Account Duration: 30 minutes
[+] Account Lockout Threshold: None
[+] Forced Log off Time: Not Set
[+] Retieved partial password policy with rpcclient:
Password Complexity: Disabled
Minimum Password Length: 0



Finding: Null session was **successful**. Extensive enumeration revealed 35+ local users (including root, msfadmin, postgres, mysql), a readable share (tmp), a weak password policy (minimum length 5, no complexity, no lockout), and Samba version **3.0.20-Debian**. The system is highly vulnerable due to outdated software and a permissive null-session configuration.

Note: There is no equivalent enumeration step for **Windows Server 2025 (192.168.100.150)** in this technique — the source document itself confirms it was **"not successfully enumerated in this run."**

Use CrackMapExec for Rapid Multi-Target Enumeration

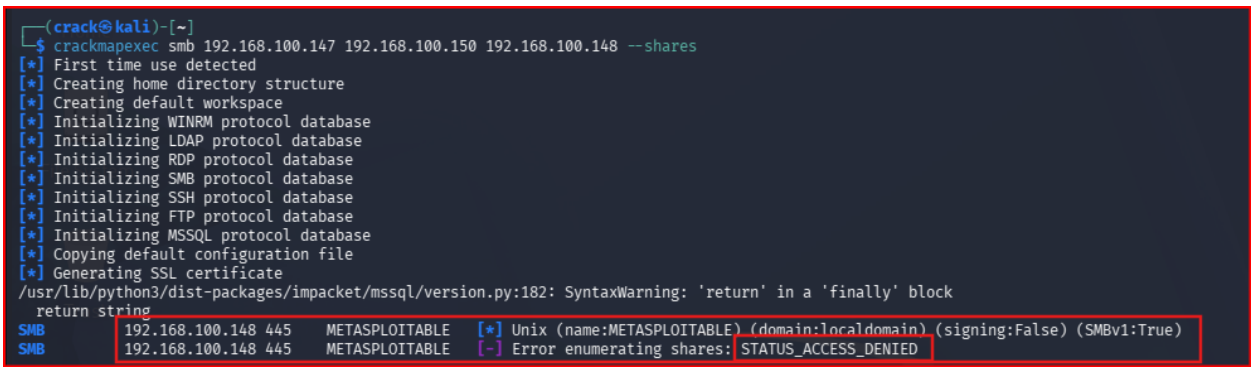
Objective: Validate SMB access across all targets simultaneously in a single pass.

Install crackmapexec (if not present)

```
sudo apt-get install -y crackmapexec
```

Rapid SMB enumeration across all targets

```
crackmapexec smb 192.168.100.147 192.168.100.150 192.168.100.148 --shares
```



Finding: (Add the observed per-host output/status here — this step is designed to cross-validate the individual enum4linux findings above in one consolidated sweep, so it's worth confirming it agrees with: Windows 10 = restricted, Metasploitable 2 = exposed.)

Summary

Target	Result
Metasploitable 2 (192.168.100.148)	Full enumeration successful (enum4linux); CrackMapExec confirmed host but denied share access
Windows 10 (192.168.100.147)	Null session blocked — expected, secure behavior
Windows Server 2025 (192.168.100.150)	**Not successfully enumerated in this run**

Technical Achievements:

- Null session enumeration successful on Metasploitable 2
- Extracted 35+ local user accounts (root, msfadmin, postgres, mysql, www-data, etc.)
- Identified shares: tmp, print$, opt, IPC$, ADMIN$
- Retrieved weak password policy (min length 5, no complexity, no lockout)
- Confirmed outdated Samba 3.0.20-Debian with SMBv1 enabled
- Windows 10 confirmed hardened: workgroup WORKGROUP, hostname DESKTOP-PQJFD86, null session blocked

Security Implications:

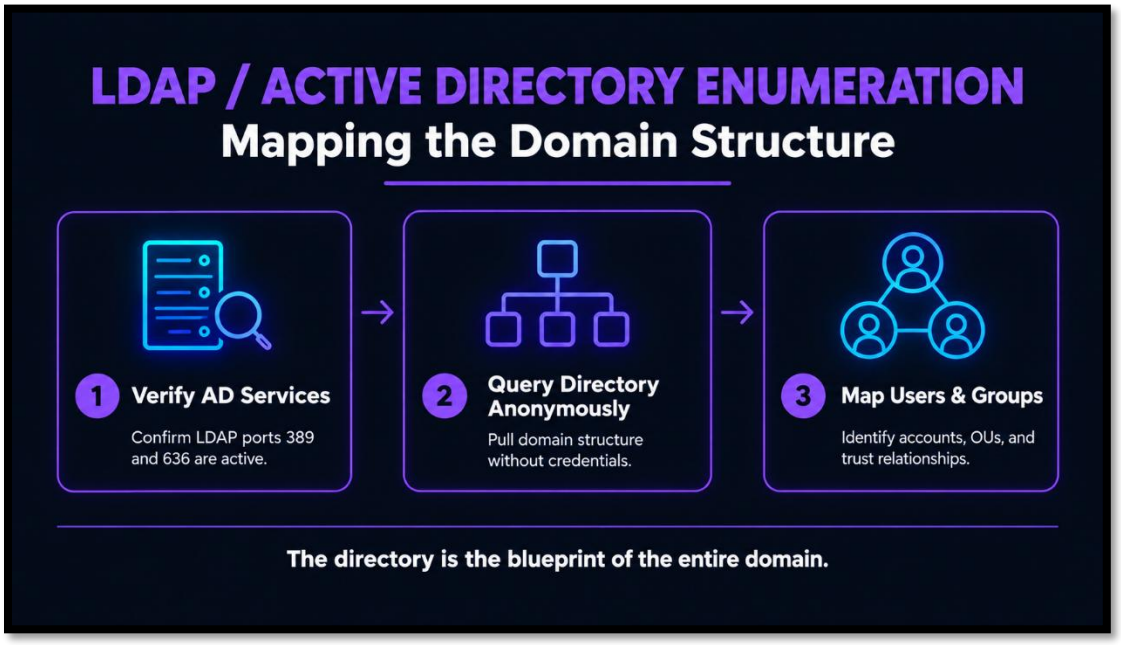
- Null sessions can reveal significant information on misconfigured/legacy systems
- Modern Windows systems block null sessions by default
- Weak password policies and outdated services increase attack surface
- Different tools (enum4linux vs. CrackMapExec) can return inconsistent results on the same target

Lab Status: Enumeration Technique #1 — **Complete**

LDAP/Active Directory Deep Enumeration

Overview

This technique performs enumeration of LDAP and Active Directory on **Windows Server 2025**, extracting domain structure, user/group accounts, computer objects, Service Principal Names (SPNs), and password policy — without requiring authenticated credentials, via null/anonymous LDAP bindings.



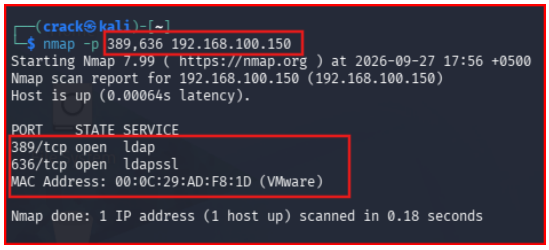
Tools: ldapsearch, GetNPUsers.py, GetUserSPNs.py, ldapdump.py, AD Explorer (GUI), Nmap NSE scripts

Risk profile: High detection risk — LDAP queries are logged (Event ID 4662, Security Event Log) but requires no authentication to attempt.

Prerequisite: Windows Server 2025 must have Active Directory Domain Services (AD DS) installed and running.

Pre-Enumeration Check — Verify Active Directory Installation

Objective: Test LDAP connectivity to Windows Server 2025 before attempting any queries.



Ports Checked:

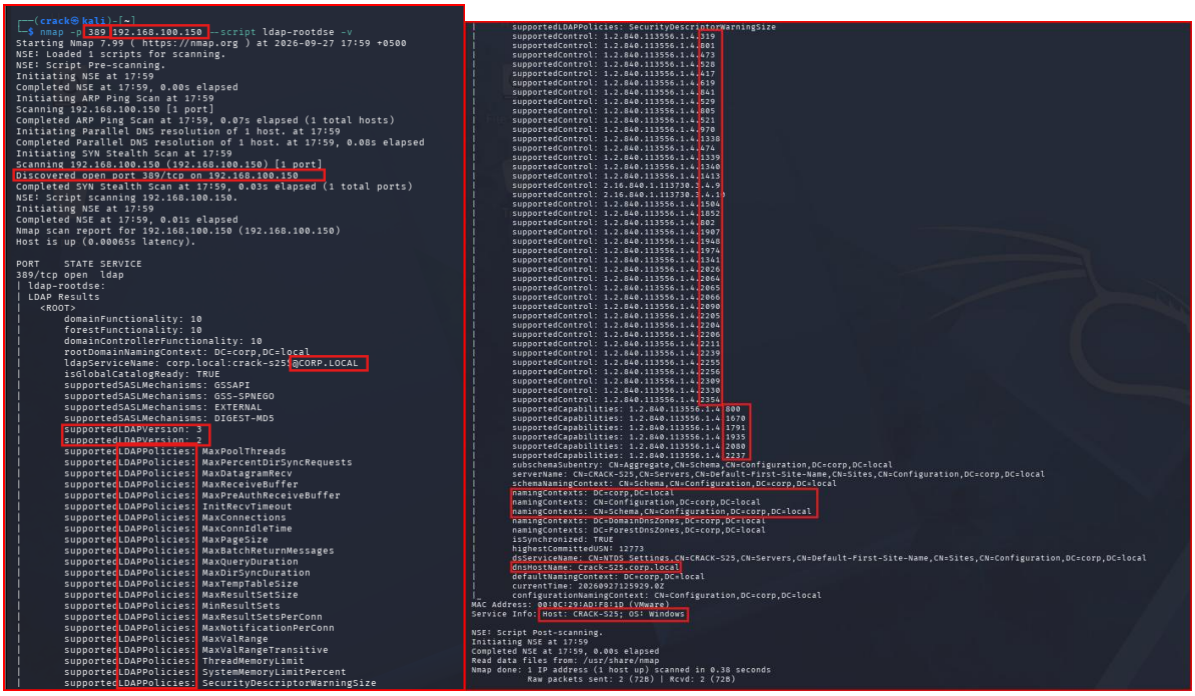
Port	Service
389/TCP	LDAP (unencrypted, standard)
636/TCP	LDAPS (encrypted, TLS/SSL)

- If ports are open → Active Directory is installed
- If ports are closed → Active Directory is not running

Verify LDAP Connectivity & Domain Information

Objective: Confirm the LDAP service is responsive and gather basic domain details.

```
nmap -p 389 192.168.100.150 --script ldap-rootdse -v
```



***Finding* — LDAP RootDSE Enumeration:** Successfully enumerated the Domain Controller. LDAP port 389 is open. Domain is **corp.local**, Domain Controller is **CRACK-S25.corp.local**. Naming contexts confirmed as DC=corp,DC=local. Domain and Forest Functional Level is 10. Active Directory is fully operational and ready for deeper enumeration (users, groups, SPNs, AS-REP roasting, etc.).

Extract Domain Information Using ldapsearch

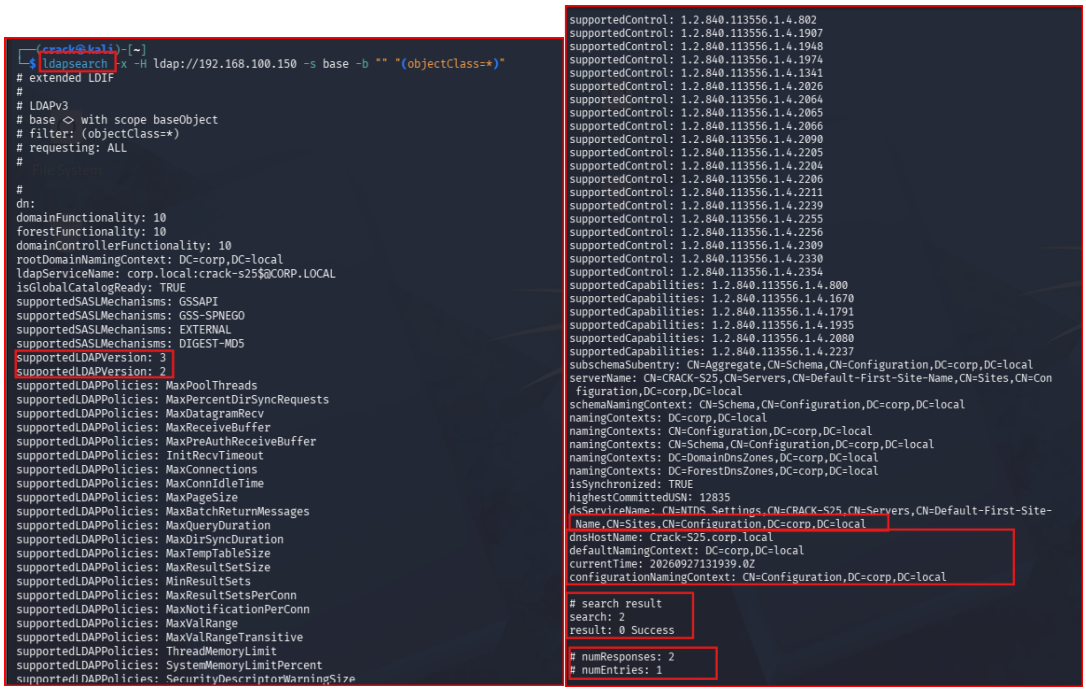
Objective: Query the LDAP directory for domain-level information via anonymous bind.

Install ldapsearch if not present

```
which ldapsearch || sudo apt-get install -y ldap-utils
```

Replace "corp" and "local" with your actual domain name

```
ldapsearch -h 192.168.100.134 -x -s base -b "DC=corp,DC=local"
"objectClass=*"
```



***Finding* — LDAP RootDSE Enumeration (192.168.100.150):** Anonymous RootDSE query was successful. Domain Controller **CRACK-S25.corp.local** is operational. Domain name confirmed as **corp.local**, Domain & Forest Functional Level is 10, LDAP versions 2 and 3 are both supported. Naming contexts confirmed (DC=corp,DC=local). Active Directory is properly configured and ready for further authenticated enumeration.

GUI-Based Enumeration Using AD Explorer

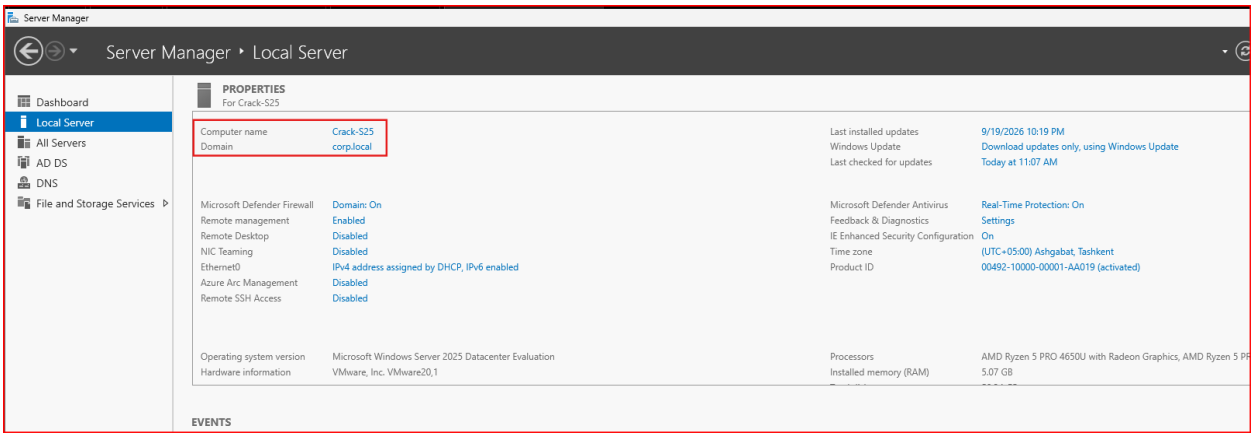
Objective: Use AD Explorer (Sysinternals GUI tool) on Windows Server 2025 to visually navigate and cross-verify the directory structure, users, groups, computer objects, and SPNs already queried via LDAP.

Risk profile: Very high detection risk — GUI-based AD access from a domain-joined system is heavily monitored and logged (Event ID 4662). For this lab, proper authorization and rules of engagement are assumed.

Everything else — the 12-item "what we'll inspect" checklist, the 6-point "why GUI after CLI" rationale, the full risk table — was restating the obvious (of course a directory browser lets you browse the directory) rather than adding anything you'd need before running the steps.

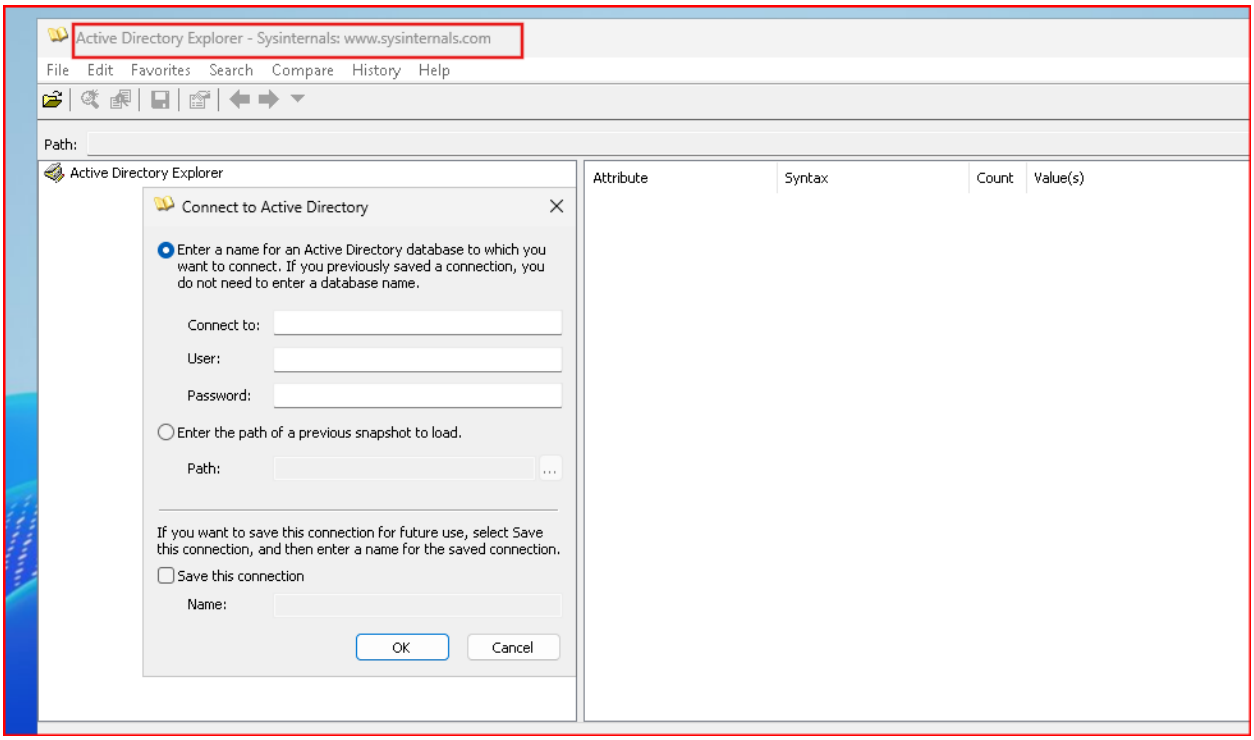
5A. Prepare Windows Server 2025 for AD Explorer

- Open the Windows Server 2025 VM via RDP or direct console, logged in as Administrator
- Open Server Manager → AD DS in the left navigation pane → confirm the Domain Controller is listed as **CRACK-S25.corp.local** with a green status indicator
- Close Server Manager — this confirms the domain controller is operational and ready for exploration



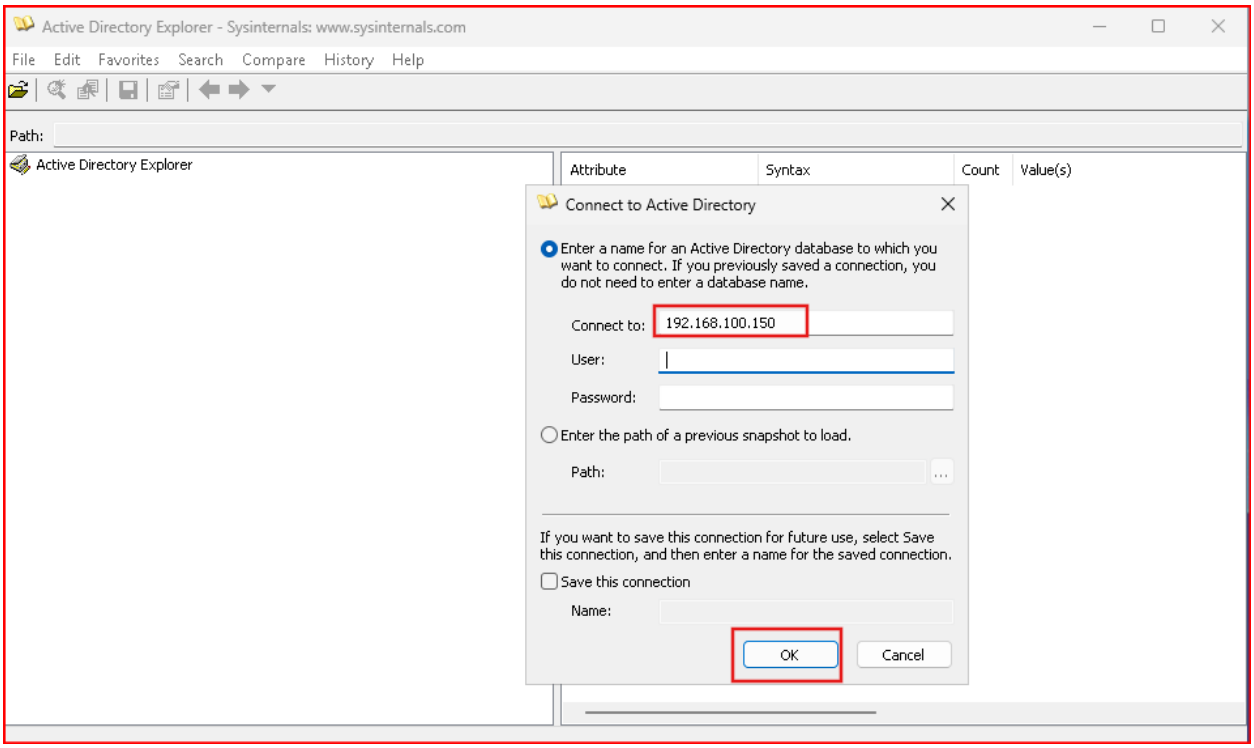
5B. Download and Install AD Explorer

- AD Explorer is a lightweight Sysinternals (Microsoft) utility, available at: https://docs.microsoft.com/en-us/sysinternals/downloads/adexplorer
- If already installed (common on enterprise domain controllers with Sysinternals pre-installed), this step can be skipped
- Verify installation via C:\Program Files\Sysinternals or by searching "AD Explorer" in the Start menu



Launch AD Explorer and Connect to the Domain Controller

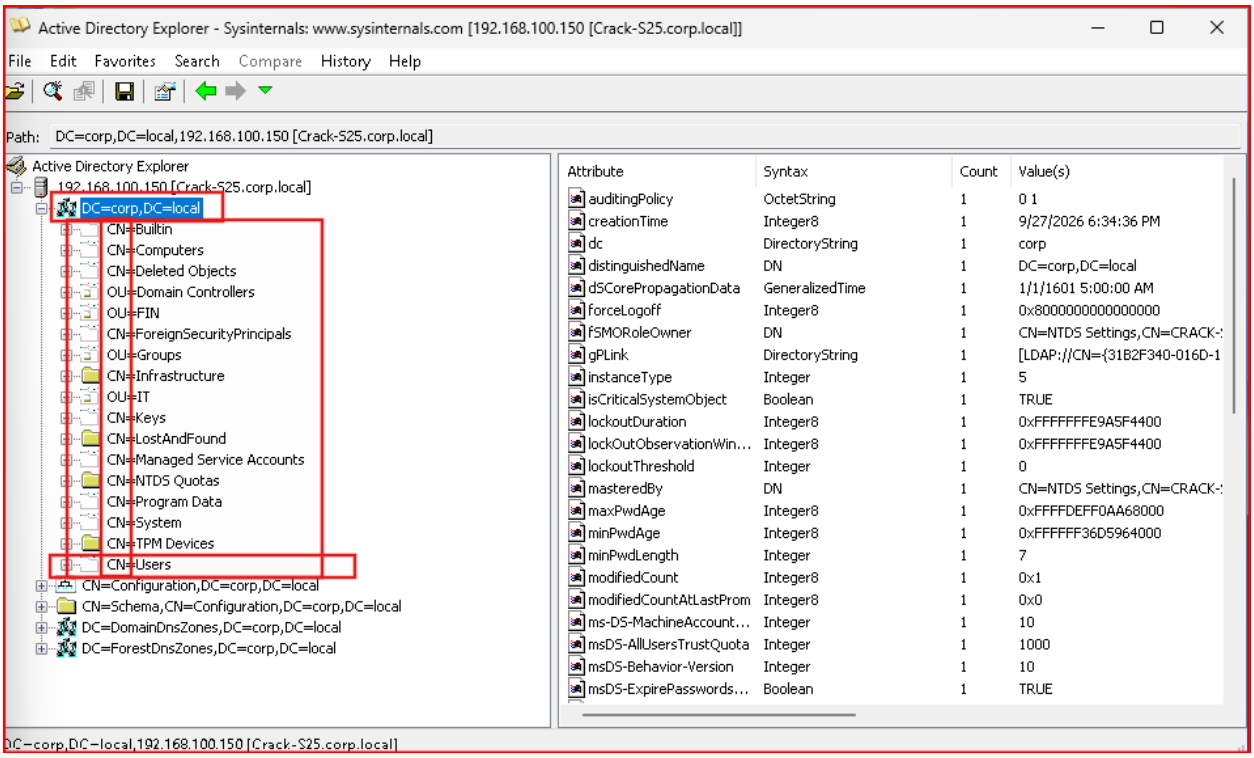
- Double-click AD Explorer.exe — a connection dialog opens requesting server details
- Enter the IP of the domain controller and click **OK**

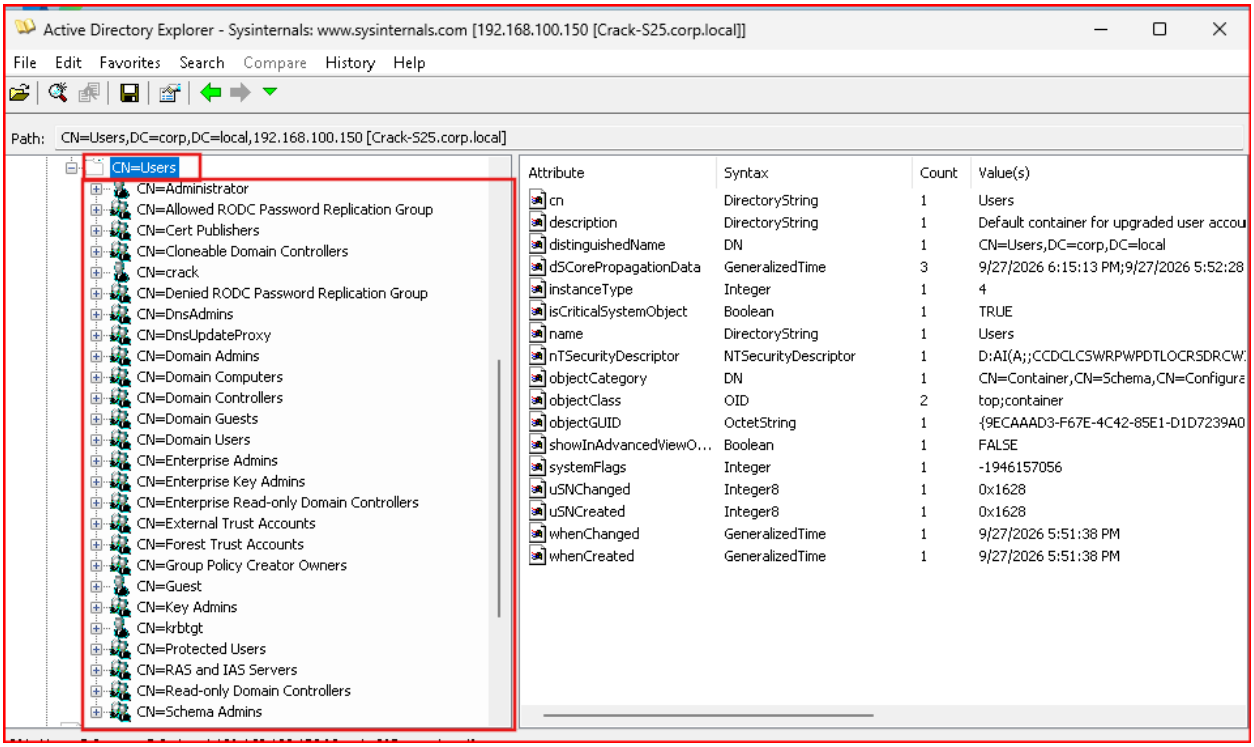


6. Navigate the Domain Structure

Once connected, the left pane displays the complete domain tree starting with DC=corp,DC=local at the root. Expanding this node (clicking the **+** symbol) unfolds the directory structure, revealing:

Container	Contents
CN=Users	Standard user and group objects
OU=Domain Controllers	Domain controller computer objects only
CN=Computers	Workstation and server computer accounts
CN=Builtin	Built-in security groups (Administrators, Users, Guests, etc.)



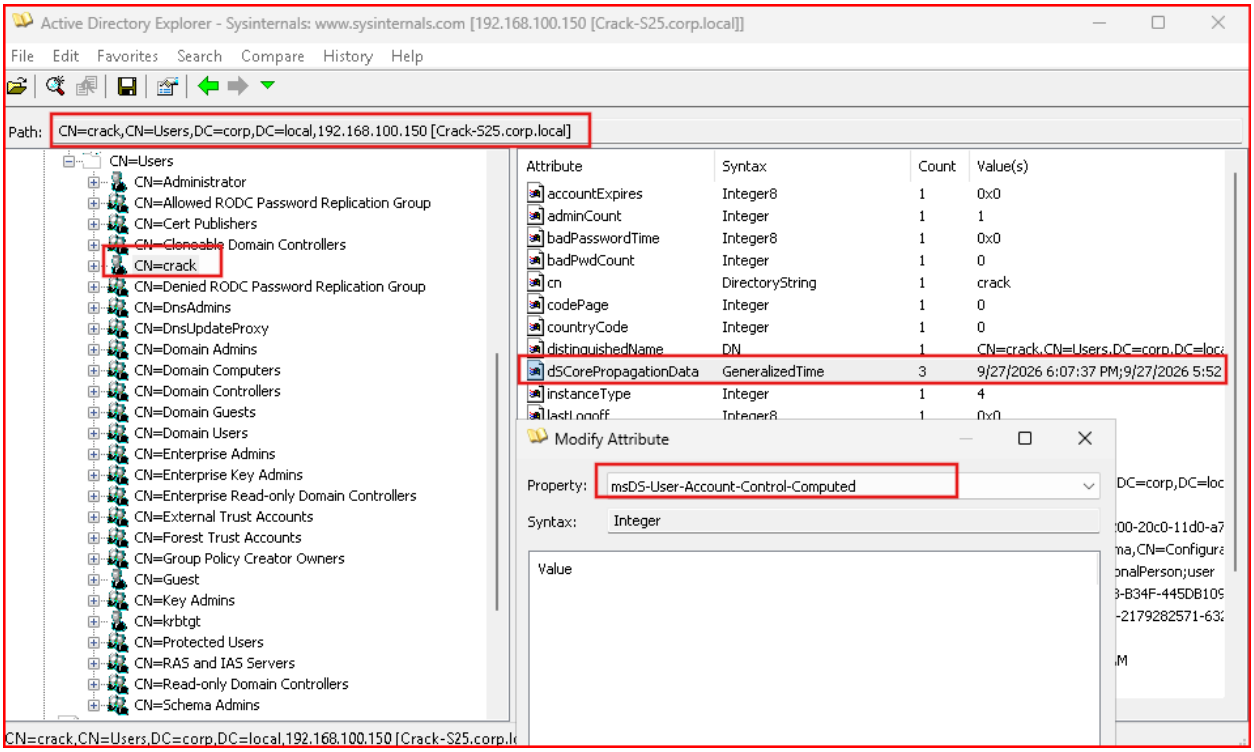


Finding: The domain tree confirms the expected AD container structure for corp.local, providing a visual map to cross-reference against the users/groups already identified via LDAP queries in Steps 3–4.

Inspect and Modify a User Attribute

The **Modify Attribute** window appears. To edit a value:

1. Select the target attribute under the **Value** section
2. Click **Modify…**
3. In the **Edit Value** pop-up, update the value in the **Value data** field
4. Click **OK** to save the change



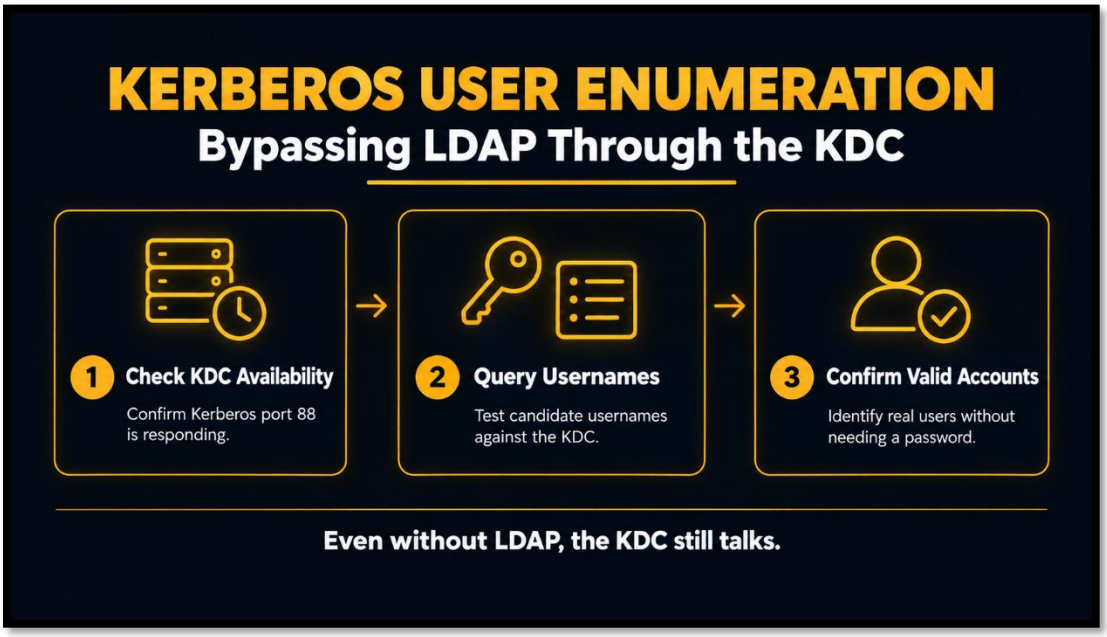
This concludes the demonstration of performing LDAP enumeration using AD Explorer.

Lab Status: Enumeration Technique #2 – **Complete**

Kerberos User Enumeration (kerbrute)

Overview

This technique enumerates valid domain usernames by querying the Kerberos Key Distribution Center (KDC) directly on **port 88/UDP**, without authentication. It works even when LDAP (port 389) is blocked, making it a valuable fallback vector against hardened networks. Confirmed usernames and AS-REP roastable accounts feed directly into later credential attacks (spraying, Kerberoasting, AS-REP roasting).



Target:

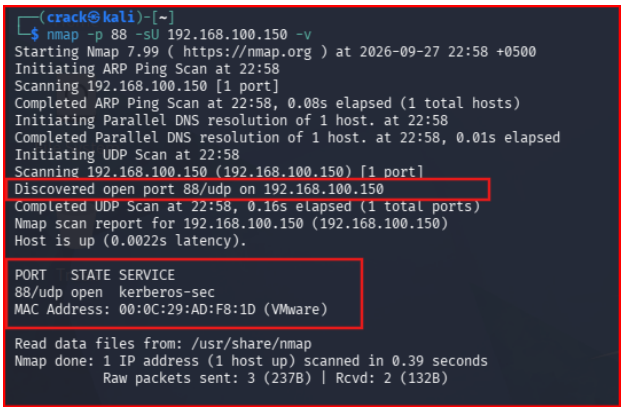
Role	System	IP / Details
Attacker	Kali Linux	192.168.100.140
Target	Windows Server 2025 Domain Controller	192.168.100.150 (CRACK-S25.corp.local), port 88/UDP, domain corp.local

Tools: kerbrute, rockyou.txt wordlist, GetNPUsers.py (secondary validation)

Risk profile: Medium detection risk — KDC logs authentication attempts (Event ID 4768) and failed enumeration attempts resemble failed login attempts — but requires no credentials or permissions to attempt. Fast: complete queries in seconds.

Verify Kerberos Service Is Running

```
nmap -p 88 -sU 192.168.100.150 -v
```



What This Means:

- Port 88/UDP open → Kerberos KDC is operational
- Port 88/UDP closed → No Kerberos service present

Install kerbrute (If Not Present)

Check if kerbrute is installed

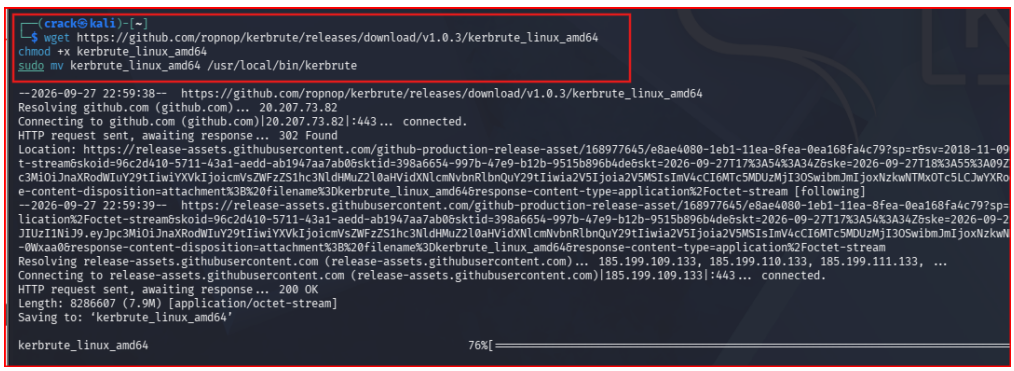
```
which kerbrute
```

If not found, download and install

```
wget
https://github.com/ropnop/kerbrute/releases/download/v1.0.3/kerb
rute_linux_amd64
```

```
chmod +x kerbrute_linux_amd64
```

```
sudo mv kerbrute_linux_amd64 /usr/local/bin/kerbrute
```



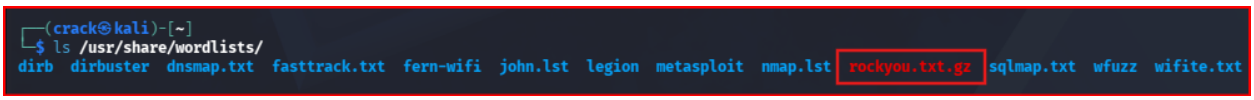
Verify installation



Prepare Usernames Wordlist

Check if rockyou.txt exists

```
ls /usr/share/wordlists/rockyou.txt
```



If missing, install it

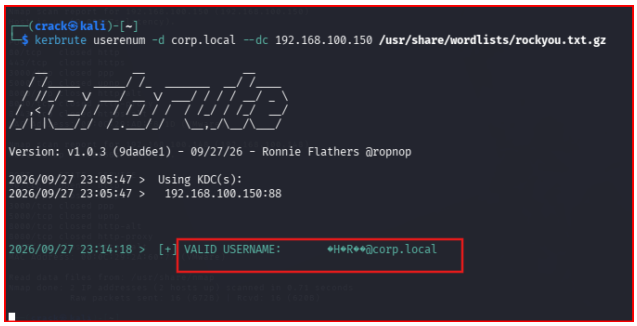
```
sudo apt-get install wordlists
```



Enumerate Users Using kerbrute

Basic User Enumeration Against Domain Controller

```
kerbrute userenum -d corp.local --dc 192.168.100.150
/usr/share/wordlists/rockyou.txt
```

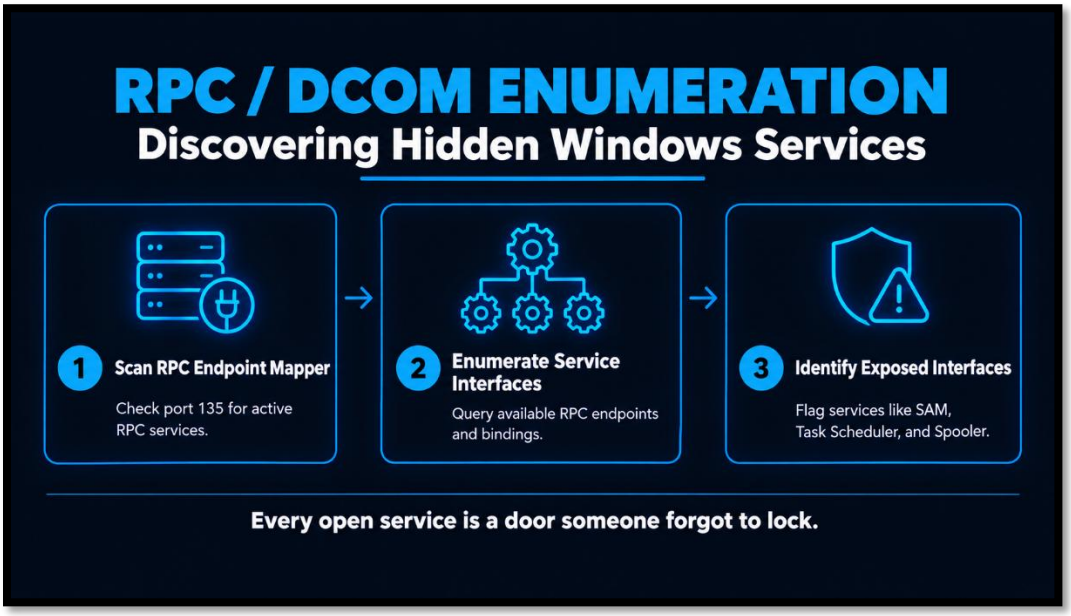


Lab Status: Enumeration Technique #3 – **Complete**

RPC/DCOM Enumeration

Overview

This technique enumerates Remote Procedure Call (RPC) and DCOM endpoints exposed on Windows systems via the RPC Endpoint Mapper (port 135/TCP). RPC underlies many core Windows services, so mapping its exposed interfaces reveals significant attack surface including account management, service control, and directory replication interfaces — without requiring authentication.



Targets:

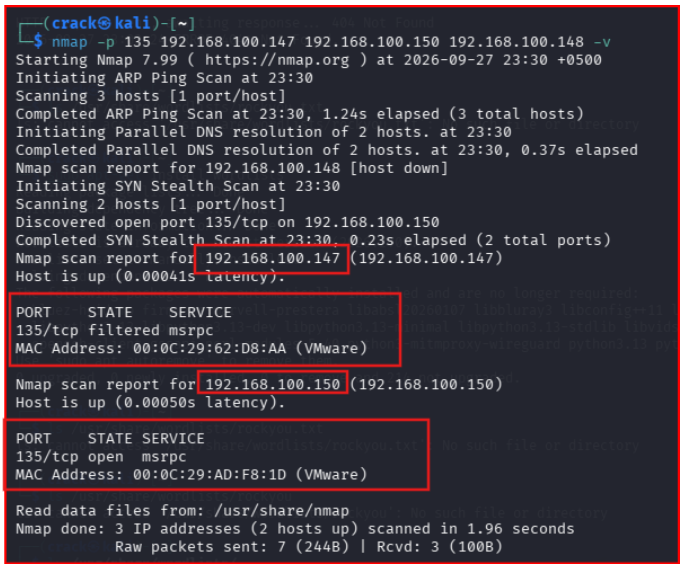
Role	System	IP
Attacker	Kali Linux	192.168.100.140
Target 1	Windows 10	192.168.100.147
Target 2	Windows Server 2025 (DC)	192.168.100.150
Target 3	Metasploitable 2	192.168.100.148

Tools: rpcdump.py (Impacket), nmap NSE scripts, enum4linux (secondary)

Risk profile: Medium detection risk — RPC access is logged (Event ID 5156) — but requires no credentials. Fast: enumeration completes in seconds.

Verify RPC Service Is Running

```
nmap -p 135 192.168.100.147 192.168.100.150 192.168.100.148 -v
```



Result: Port 135/TCP was open on 192.168.100.150 (Windows Server 2025) and filtered on 192.168.100.147 (Windows 10). Metasploitable 2 (192.168.100.148) reported as host down for this scan.

Install Impacket rpcdump (If Needed)

Check if rpcdump.py is available

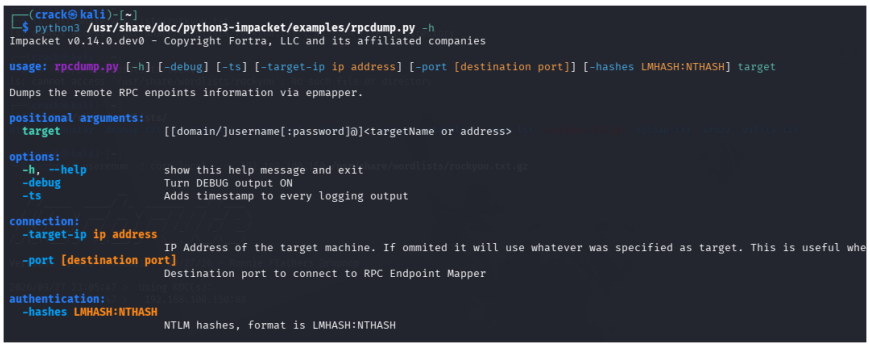
```
python3 /usr/share/doc/python3-impacket/examples/rpcdump.py -h
```

If not found, install impacket

```
python3 -m pip install impacket --upgrade
```

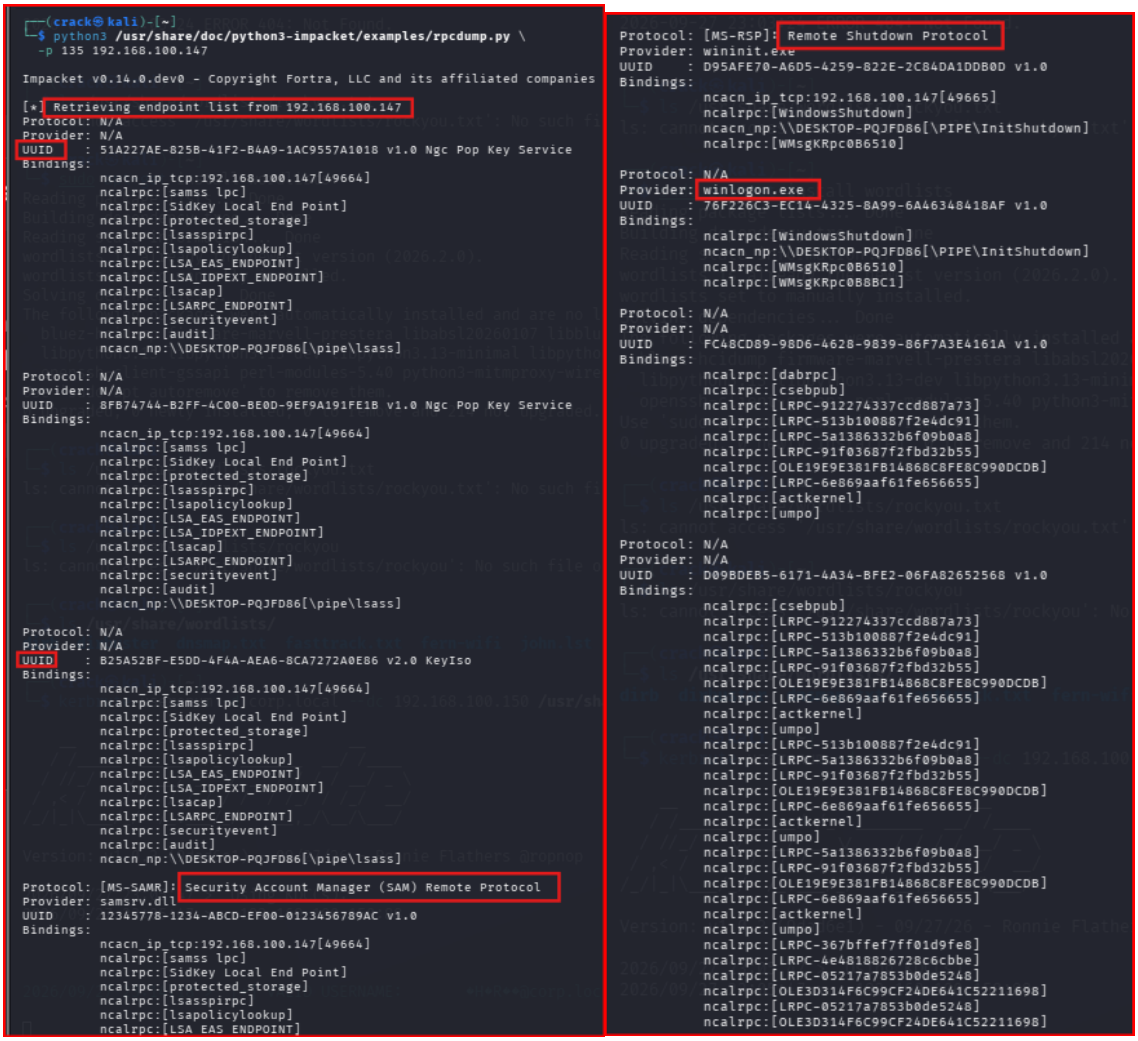
Verify installation

```
python3 -c "from impacket import examples; print('Impacket installed')"
```



Enumerate RPC Endpoints — Windows 10

```
python3 /usr/share/doc/python3-impacket/examples/rpcdump.py -p
135 192.168.100.147
```



Key Findings (192.168.100.147 — DESKTOP-PQJFD86):

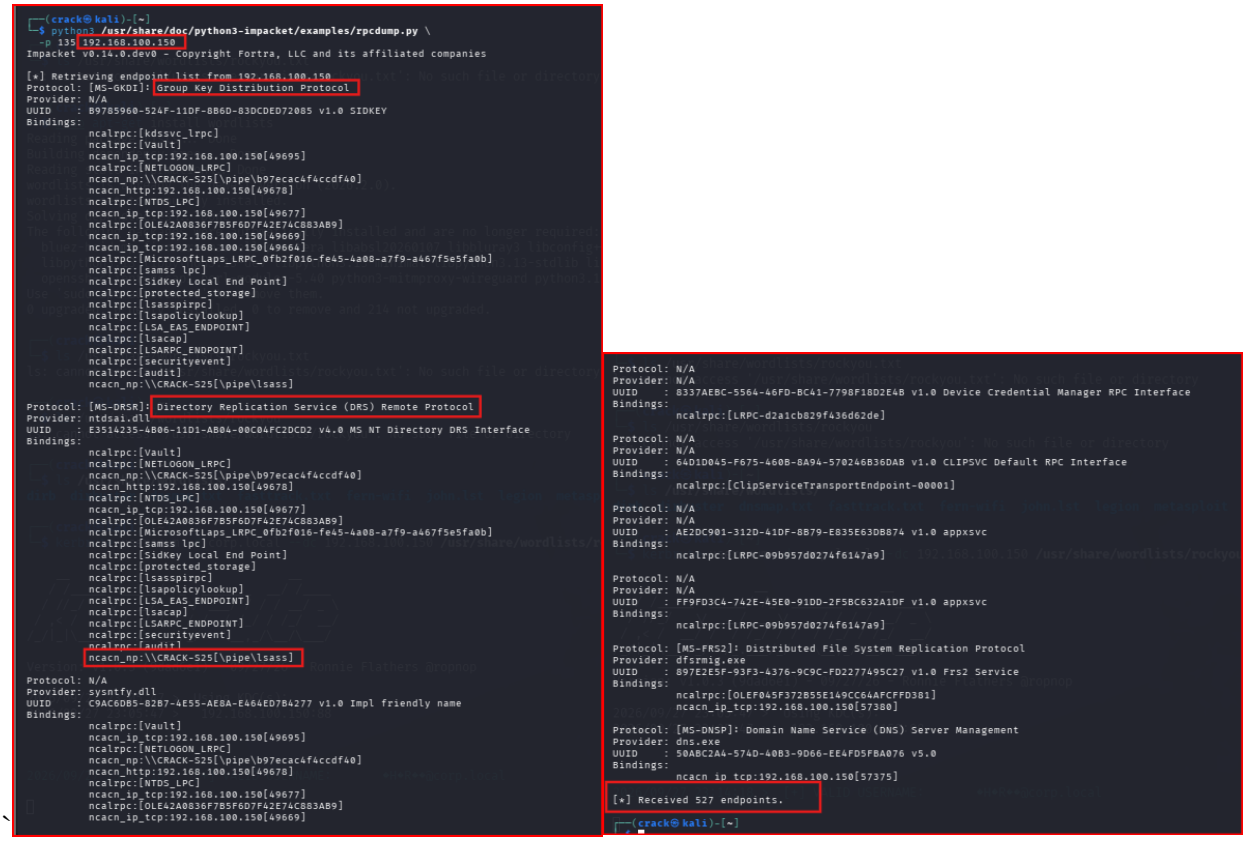
Category	Result
RPC mapper queried	TCP 135
Endpoints discovered	351
Dynamic RPC ports	49664, 49665, 49666, 49667, 49668, 49673, 49901
SAM available	Yes (samsrv.dll)
Task Scheduler	Yes
Windows Event Log	Yes
Service Control Manager	Yes
Print Spooler RPC	Yes
Windows Firewall RPC	Yes
Named pipes observed	lsass, atsvc, eventlog, wkssvc, ROUTER, etc.

Significant remote services identified:

- 49664 → SAM / KeyIso / Ngc Pop Key
- 49665 → Remote Shutdown
- 49666 → Windows Event Log
- 49667 → Task Scheduler
- 49668 → Print Spooler RPC
- 49673 → Service Control Manager
- 49901 → Windows Firewall Remote APIs

Enumerate RPC Endpoints — Windows Server 2025 (Domain Controller)

```
python3 /usr/share/doc/python3-impacket/examples/rpcdump.py -p 135 192.168.100.150 > /tmp/rpc_endpoints_dc.txt
```



Key Findings (192.168.100.150 — CRACK-S25.corp.local): 527 RPC endpoints returned — substantially more than the workstation, consistent with a domain controller's expanded service set.

RPC Service	Provider	Port/Binding	Purpose
Security Account Manager (SAM)	samsrv.dll	49664	Remote account/security management
Ngc Pop Key Service	—	49664	Windows credential/key functionality
KeyIso	—	49664	Key isolation / cryptographic operations
Remote Shutdown	wininit.exe	49665	Remote shutdown/restart
Windows Event Log	wevtsvc.dll	49666	Event-log management
Task Scheduler	schedsvc.dll	49667	Remote task scheduling
Print System RPC	spoolsv.exe	49668	Print-service RPC
Service Control Manager	services.exe	49673	Remote service management
Firewall Remote APIs	FwRemoteSvr.dll	49901	Windows Firewall management
Group Policy RPC	gpsvc.dll	ncalrpc	Group Policy functionality
Security Center	wscsvc.dll	ncalrpc	Windows Security Center
AppInfo	appinfo.dll	ncalrpc	Elevation/application info
DHCP Client	dhcpcsvc.dll	ncalrpc	DHCP client operations
IKE/AuthIP API	IKEEXT.DLL	ncalrpc	IPsec/IKE functionality

Domain-specific interfaces of note: **MS-GKDI** (Group Key Distribution Protocol) and **MS-DRSR** (Directory Replication Service Remote Protocol / DRSUAPI) were both exposed via ncacn_np:\\CRACK-S25\pipe\lsass — DRSUAPI is significant because, with valid credentials, it enables DCSync-style domain replication attacks.

Summary

Technical Achievements:

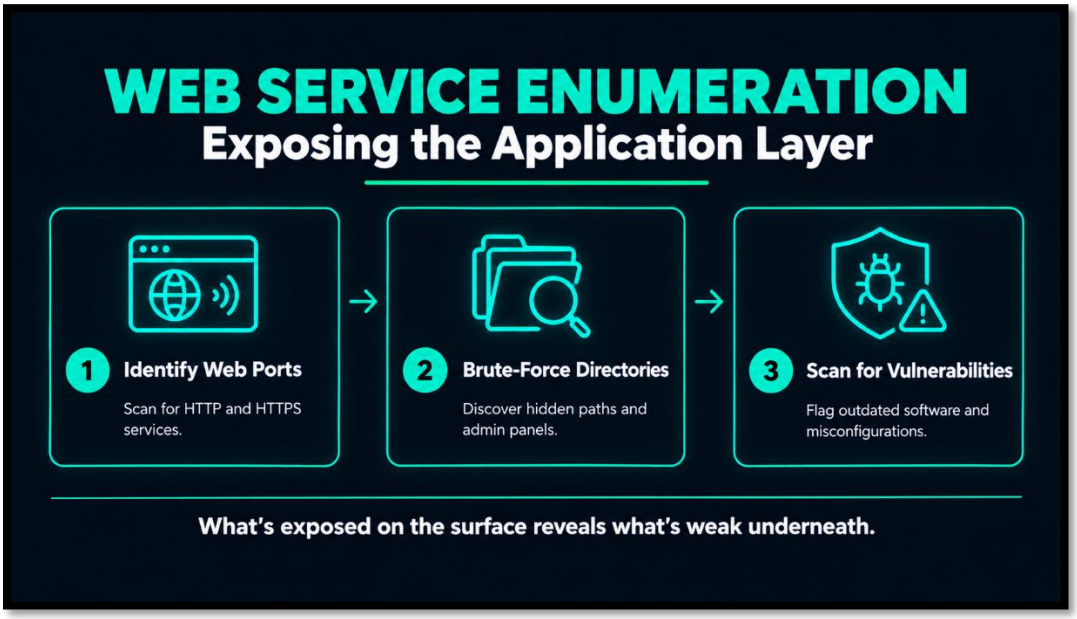
- Identified accessible RPC endpoints on both Windows targets (351 on the workstation, 527 on the DC)
- Confirmed SAMR interface exposure (user/account enumeration surface)
- Mapped DRSUAPI (directory replication) and MS-GKDI interfaces on the DC
- Discovered SVCCTL (service control) and SPOOLSS (print spooler) interfaces
- Catalogued dynamic RPC ports and named pipes for both hosts

Security Implication: RPC interface exposure by itself does not grant access, but it maps precisely which subsystems (SAM, DRS, service control, print spooler) would become attack vectors once valid credentials are obtained — informing later privilege-escalation and lateral-movement planning

Web Service Enumeration

Overview

This technique enumerates web-facing services (HTTP/HTTPS) to identify server software, exposed directories, and technology stack details on lab targets. Web services represent a distinct attack surface from the network/directory-level services covered in Techniques #1–#4.



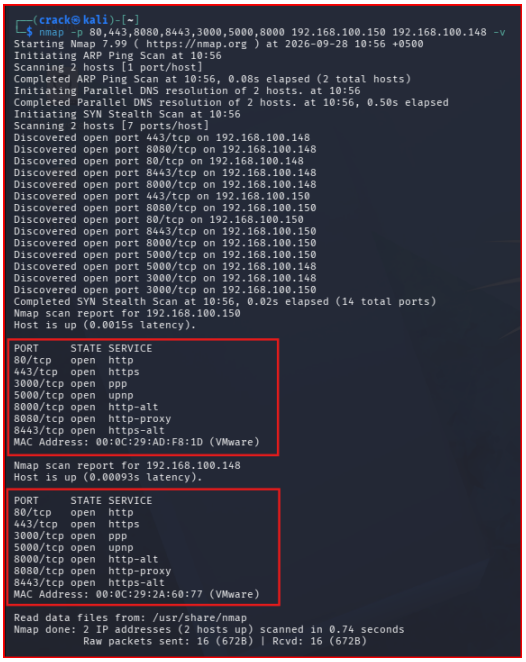
Targets: Metasploitable 2 (192.168.100.148, Apache/HTTP), Windows Server 2025 (192.168.100.150)

Tools: gobuster, ffuf, whatweb, nikto, nmap NSE scripts

Risk profile: Medium detection risk (logged in web server logs) — no authentication required.

Identify Active Web Services

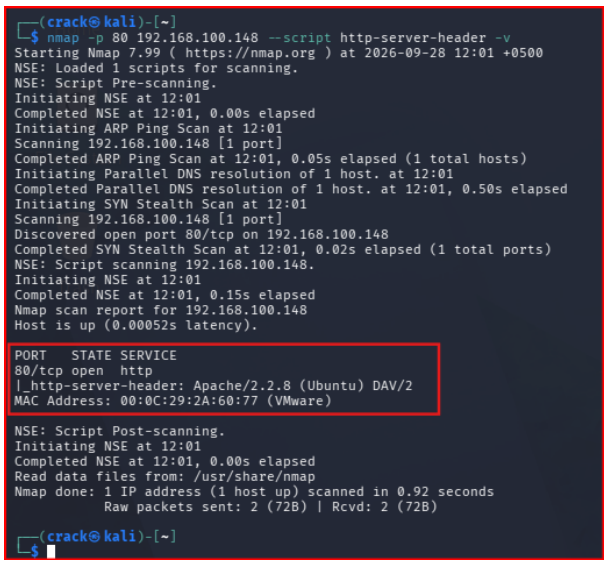
```
nmap -p 80,443,8080,8443,3000,5000,8000 192.168.100.150
192.168.100.148 -v
```



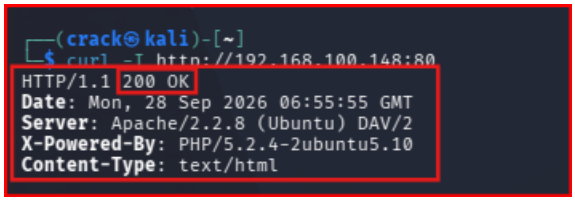
Result: Both targets returned multiple open web-related ports (80, 443, 3000, 5000, 8000, 8080, 8443), indicating several listening HTTP/HTTPS services beyond the primary application port.

Fingerprint the Web Server

```
nmap -p 80 192.168.100.148 --script http-server-header -v
```



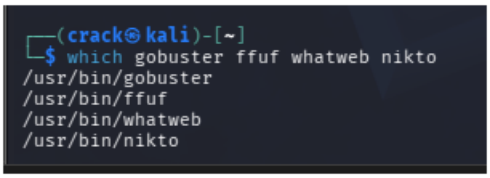
```
curl -I http://192.168.100.148:80
```



Result: Apache/2.2.8 (Ubuntu) with WebDAV (DAV/2) enabled; PHP/5.2.4-2ubuntu5.10 confirmed via the X-Powered-By header.

Technology Fingerprinting

```
which gobuster ffuf whatweb nikto
```




```
whatweb http://192.168.100.148 -v
```

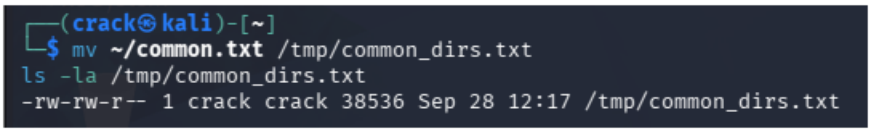


Result: Confirmed Apache 2.2.8, Ubuntu Linux OS, PHP 5.2.4, and WebDAV v2 — a stack consistent with a deliberately outdated, vulnerable target.

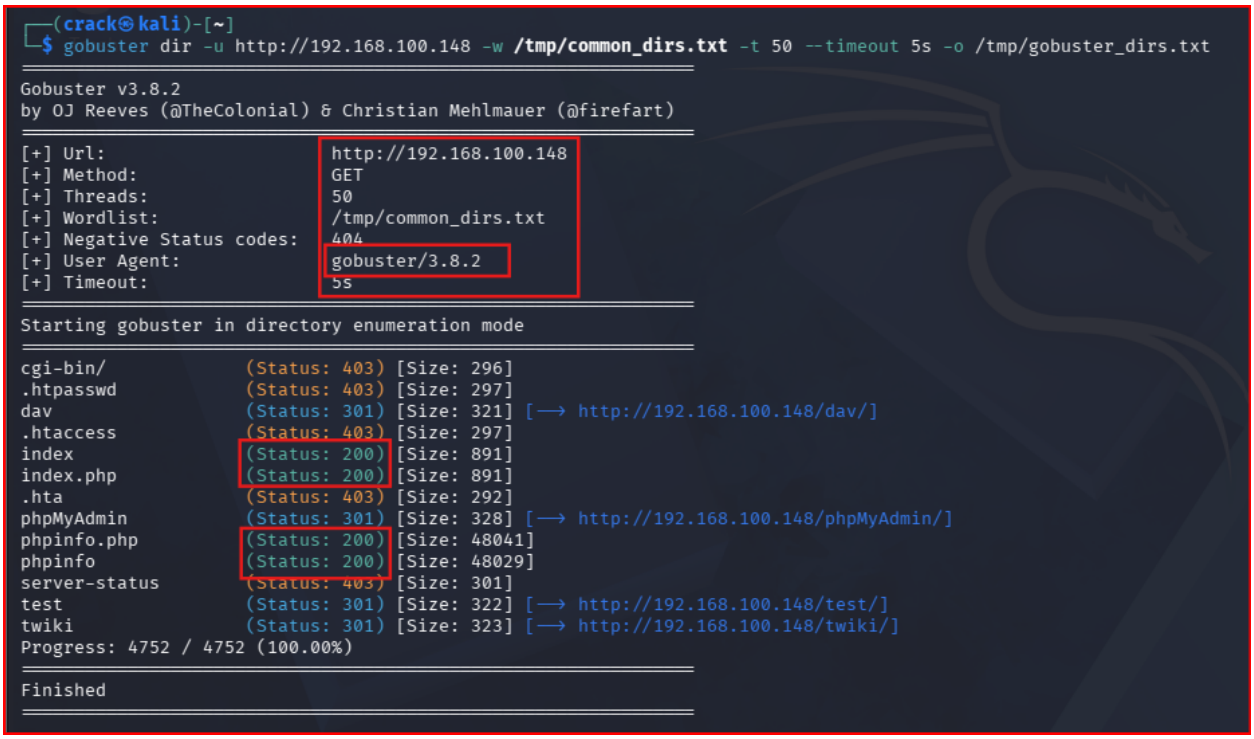
Directory Brute-Forcing (Gobuster)

wget https://raw.githubusercontent.com/danielmiessler/SecLists/master/Discovery/Web-Content/common.txt -O /tmp/common_dirs.txt





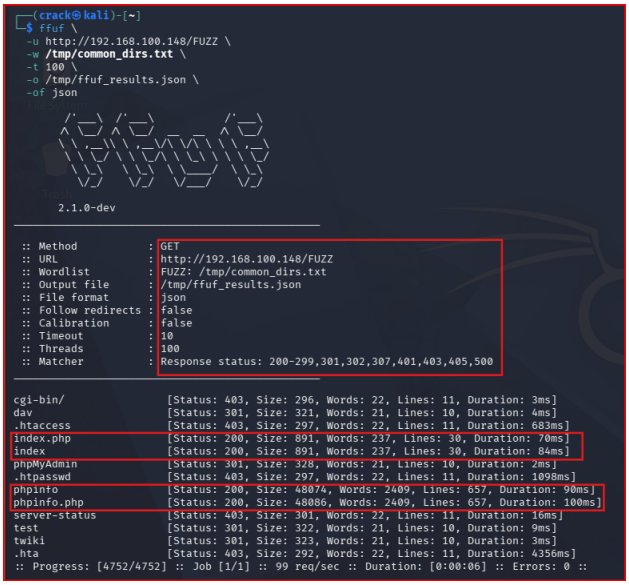

```
gobuster dir -u http://192.168.100.148 -w /tmp/common_dirs.txt -t 50 --timeout 5s -o /tmp/gobuster_dirs.txt
```



Result: 4,752 paths tested (100% complete). Notable hits: index/index.php (200), phpMyAdmin (301), phpinfo/phpinfo.php (200), test/twiki (301), plus several 403-forbidden paths (cgi-bin/, .htpasswd, .htaccess, server-status).

High-Speed Fuzzing (ffuf)

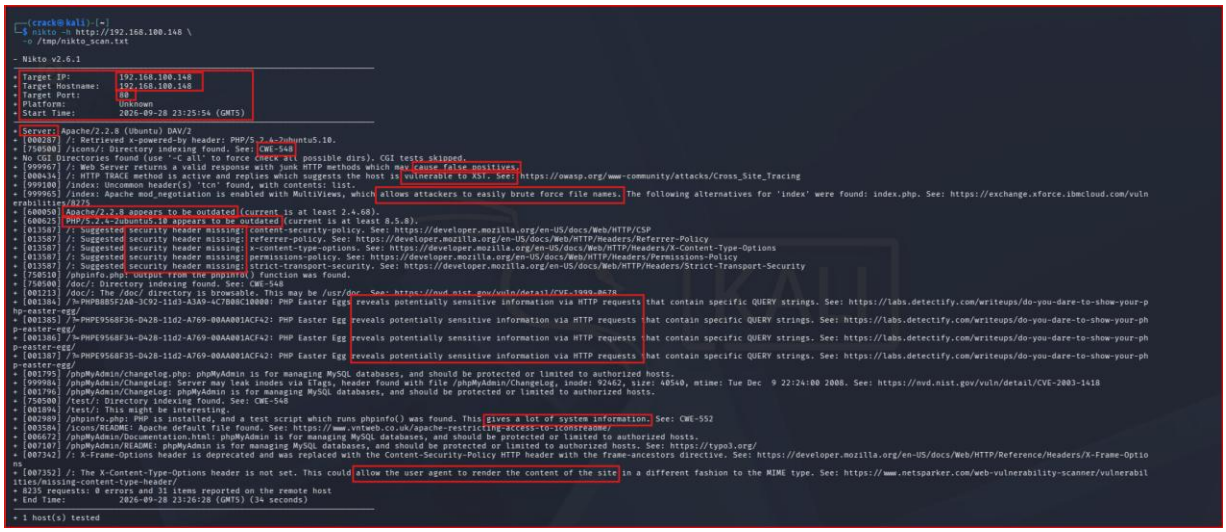
```
ffuf -u http://192.168.100.148/FUZZ -w /tmp/common_dirs.txt -t 100 -o /tmp/ffuf_results.json -of json
```



Result: Same findings as Gobuster, confirmed independently and completed faster (~6 seconds at 100 threads vs. Gobuster's 50).

Vulnerability Scanning (Nikto)

```
nikto -h http://192.168.100.148 -o /tmp/nikto_scan.txt
```



Result: 8,235 requests sent, 31 issues identified in 34 seconds — outdated Apache/PHP with known CVEs, missing security headers, directory listing enabled, and exposed phpMyAdmin/phpinfo endpoints.

API Endpoint Enumeration

```
ffuf -u http://192.168.100.148/FUZZ -w /tmp/api_endpoints.txt -t 50 --timeout 5s
```



Result: No matches against the tested API path list (/api, /api/v1, /api/users, /api/login, etc.) — expected, since Metasploitable 2 is a legacy LAMP-style target without a REST/modern API layer.

Summary

Technical Achievements:

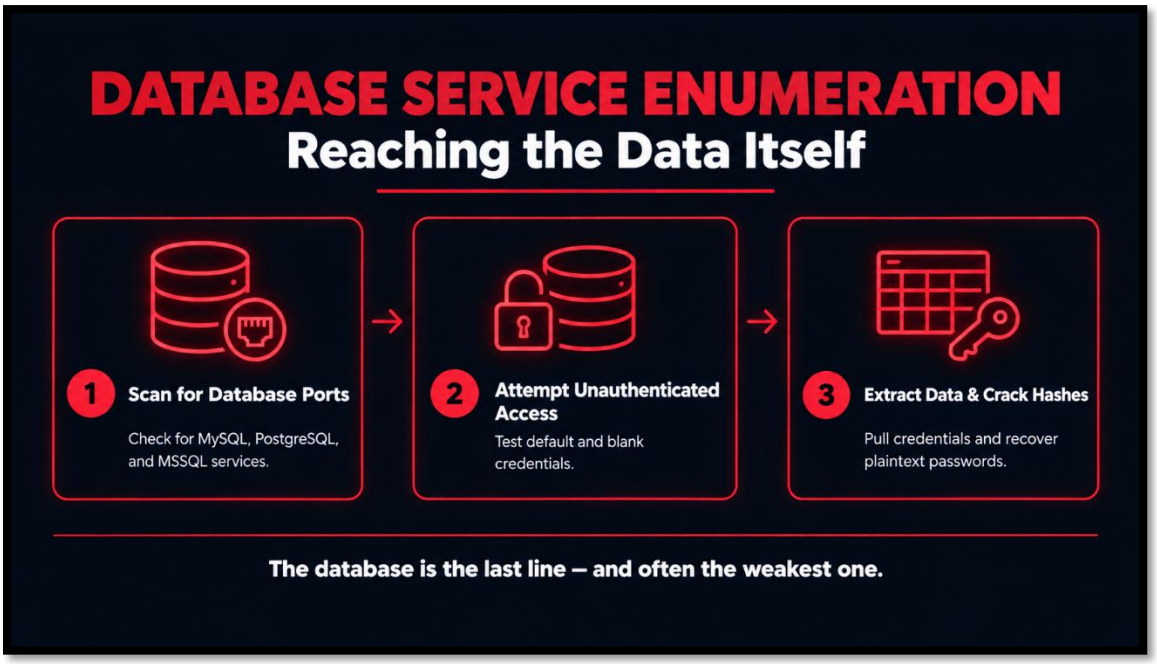
- Fingerprinted Apache 2.2.8 (Ubuntu) with PHP 5.2.4 and WebDAV enabled
- Identified exposed administrative interfaces (phpMyAdmin, phpinfo)
- Cross-validated directory findings across two independent tools (Gobuster, ffuf)
- Confirmed the target's outdated software stack via Nikto's CVE-aware scan
- Ruled out a modern API attack surface on this particular host

Security Implication: Exposed phpinfo.php and phpMyAdmin are high-value information-disclosure findings — they can leak full server configuration, installed modules, and, in phpMyAdmin's case, offer a direct path to database access if default/weak credentials are in use (validated further in Technique #6).

Database Service Enumeration

Overview

This technique enumerates exposed database services to identify server type/version, accessible databases, user accounts, and stored data — testing specifically for unauthenticated or default-credential access.

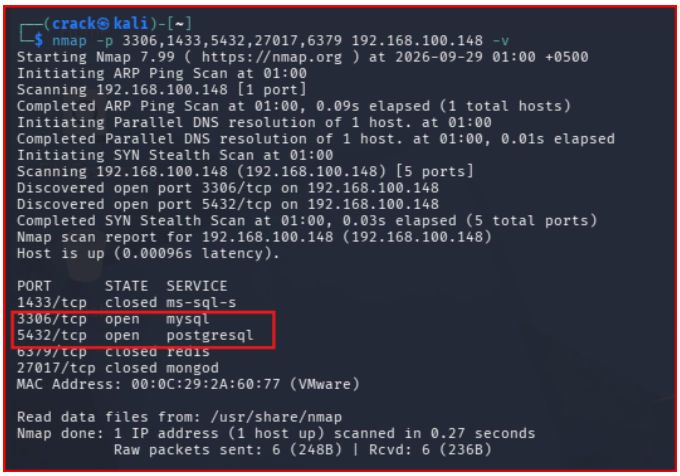


Tools: nmap NSE scripts, mysql-client, hashcat/John the Ripper (offline cracking)

Targets: Metasploitable 2 (192.168.100.148) — MySQL (3306), PostgreSQL (5432)

Identify Database Services

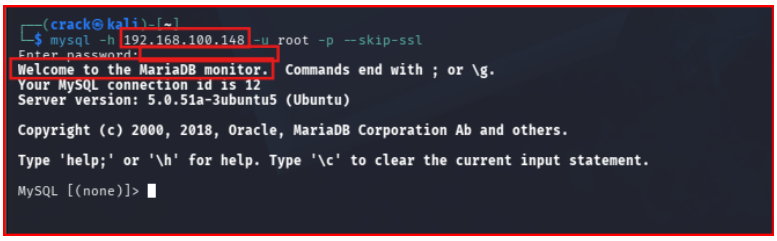
```
nmap -p 3306,1433,5432,27017,6379 192.168.100.148 -v
```



Result: MySQL (3306) and PostgreSQL (5432) confirmed open and reachable without restriction. MSSQL (1433), Redis (6379), and MongoDB (27017) were closed.

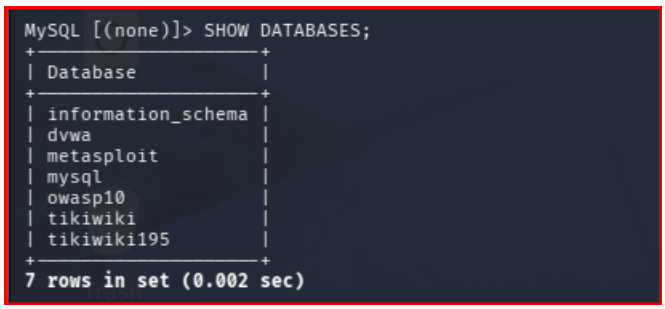
Enumerate MySQL

```
mysql -h 192.168.100.148 -u root -p --skip-ssl
```



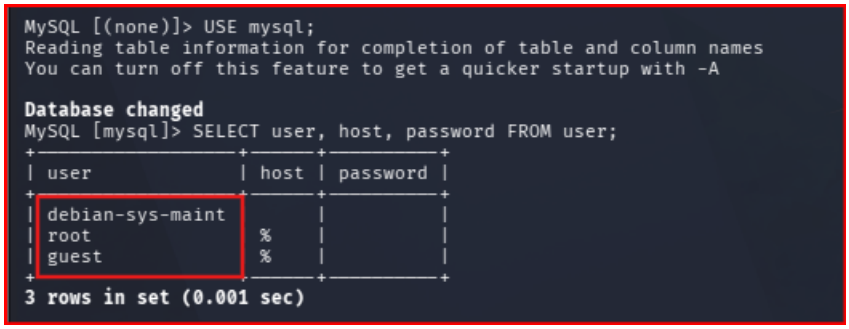
Result: Connected as root with **no password**, confirming a critical unauthenticated-access vulnerability. SSL had to be disabled due to a TLS mismatch between the modern client and the outdated MySQL 5.0.51a (MariaDB-based) server.

Databases enumerated (7 total): information_schema, dvwa, metasploit, mysql, owasp10, tikiwiki, tikiwiki195



```
MySQL [(none)]> SHOW DATABASES;
+--------------------+
| Database           |
+--------------------+
| information_schema |
| dvwa               |
| metasploit         |
| mysql              |
| owasp10            |
| tikiwiki           |
| tikiwiki195        |
+--------------------+
7 rows in set (0.002 sec)
```

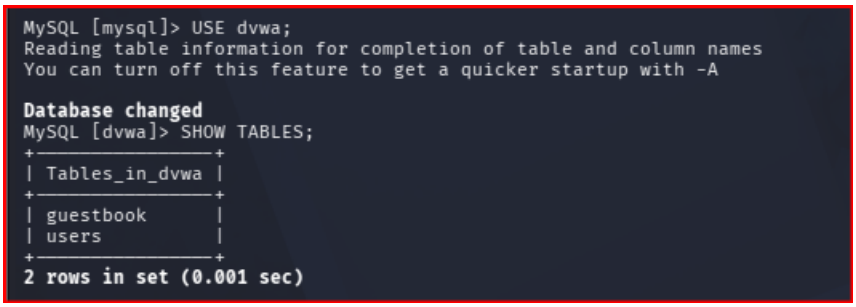
MySQL system users (from mysql.user): debian-sys-maint, root, guest



```
MySQL [(none)]> USE mysql;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
MySQL [mysql]> SELECT user, host, password FROM user;
+------------------+------+----------+
| user             | host | password |
+------------------+------+----------+
| debian-sys-maint |      |          |
| root             | %    |          |
| guest            | %    |          |
+------------------+------+----------+
3 rows in set (0.001 sec)
```

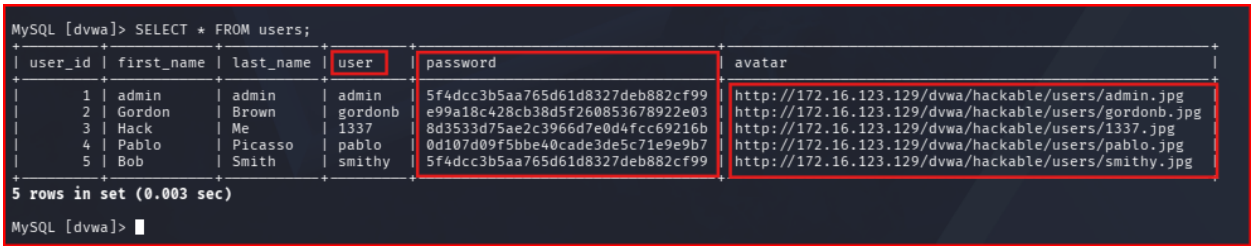
DVWA tables: guestbook, users



```
MySQL [mysql]> USE dvwa;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
MySQL [dvwa]> SHOW TABLES;
+----------------+
| Tables_in_dvwa |
+----------------+
| guestbook      |
| users          |
+----------------+
2 rows in set (0.001 sec)
```

Extracted credentials from dvwa.users:

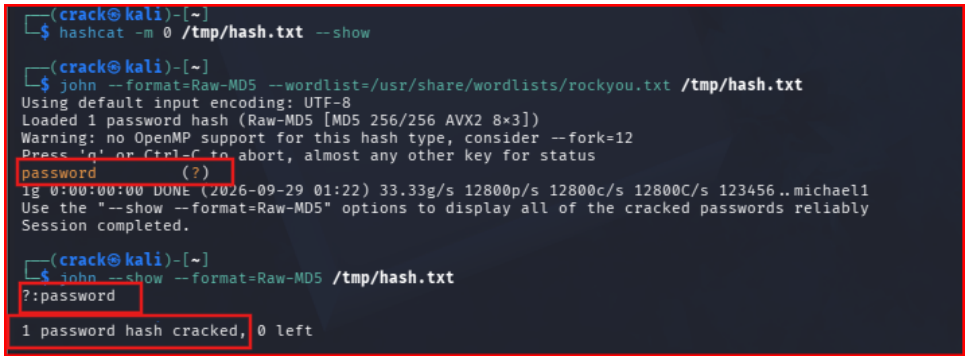


```
MySQL [dvwa]> SELECT * FROM users;
+---------+------------+-----------+---------+----------------------------------+-----------------------------------------------------+
| user_id | first_name | last_name | user    | password                         | avatar                                              |
+---------+------------+-----------+---------+----------------------------------+-----------------------------------------------------+
|       1 | admin      | admin     | admin   | 5f4dcc3b5aa765d61d8327deb882cf99 | http://172.16.123.129/dvwa/hackable/users/admin.jpg |
|       2 | Gordon     | Brown     | gordonb | e99a18c428cb38d5f260853678922e03 | http://172.16.123.129/dvwa/hackable/users/gordonb.jpg |
|       3 | Hack       | Me        | 1337    | 8d3533d75ae2c3966d7e0d4fcc69216b | http://172.16.123.129/dvwa/hackable/users/1337.jpg  |
|       4 | Pablo      | Picasso   | pablo   | 0d107d09f5bbe40cade3de5c71e9e9b7 | http://172.16.123.129/dvwa/hackable/users/pablo.jpg |
|       5 | Bob        | Smith     | smithy  | 5f4dcc3b5aa765d61d8327deb882cf99 | http://172.16.123.129/dvwa/hackable/users/smithy.jpg |
+---------+------------+-----------+---------+----------------------------------+-----------------------------------------------------+
5 rows in set (0.003 sec)

MySQL [dvwa]>
```

Offline Hash Cracking

```
echo "5f4dcc3b5aa765d61d8327deb882cf99" | hashcat -m 0 -a 0 -
/usr/share/wordlists/rockyou.txt
```



Using the MD5 hash extracted from the DVWA users table (5f4dcc3b5aa765d61d8327deb882cf99), we performed an offline dictionary attack with John the Ripper against the rockyou.txt wordlist.

Result: The hash was cracked instantly, revealing the plaintext password **password** — used by both the admin and smithy accounts. This confirms weak, easily guessable credentials are in active use on the target application, significantly lowering the barrier for account takeover.

Summary

Technical Achievements:

- Confirmed unauthenticated root access to MySQL (no password required)
- Enumerated 7 databases, including application (dvwa) and platform (metasploit) schemas
- Extracted and cracked application user credentials via offline dictionary attack
- Identified PostgreSQL as a second open, unvalidated database service for follow-up testing

Security Implication: Unauthenticated root-level database access is a critical finding — it grants full read/write access to all hosted schemas and demonstrates how a single misconfiguration (blank root password) can cascade into full credential disclosure once combined with basic password-cracking.

Conclusion

This concludes the enumeration phase of the Advanced Network Scanning Lab, conducted within the isolated 192.168.100.0/24 VirtualBox host-only network against Metasploitable 2, DVWA, Windows 10, and Windows Server 2025 targets.

#	Technique	Primary Target(s)	Key Outcome
1	SMB/CIFS Deep Enumeration	Metasploitable 2, Windows 10, Windows Server 2025	Full null-session enumeration succeeded on Metasploitable (35+ users, weak password policy); modern Windows hosts correctly blocked null sessions
2	LDAP/Active Directory Enumeration	Windows Server 2025	Domain structure, naming contexts, and functional levels confirmed via anonymous LDAP bind; full directory tree mapped with AD Explorer
3	Kerberos User Enumeration	Windows Server 2025 (KDC)	Valid domain username(s) confirmed via unauthenticated kerbrute queries against port 88/UDP — a working fallback when LDAP is hardened
4	RPC/DCOM Enumeration	Windows 10, Windows Server 2025	351 and 527 RPC endpoints mapped respectively, exposing SAM, DRSUAPI, SVCCTL, and SPOOLSS interfaces
5	Web Service Enumeration	Metasploitable 2	Apache 2.2.8/PHP 5.2.4 fingerprinted; phpMyAdmin and phpinfo exposure confirmed and cross-validated across three tools
6	Database Service Enumeration	Metasploitable 2	Unauthenticated root access to MySQL confirmed; application credentials extracted and cracked offline in seconds

Overall Findings

The lab environment — by design — demonstrated a clear contrast between **hardened** and **intentionally vulnerable** systems:

- **Metasploitable 2** proved fully exploitable at every layer tested: null SMB sessions, unauthenticated database root access, exposed web management interfaces, and weak, crackable credentials.
- **Windows Server 2025 and Windows 10**, while not vulnerable to the same unauthenticated attacks (SMB null sessions were correctly blocked), still exposed a substantial RPC and LDAP attack surface consistent with default enterprise configurations, providing realistic reconnaissance data for follow-on credentialed attack planning.

Cumulative Intelligence Gathered

Combined across all six techniques, this enumeration phase produced:

- Confirmed user accounts, groups, and domain structure
- A mapped RPC/service interface attack surface on both Windows hosts
- Validated web application technology stack and exposed management endpoints
- Extracted and cracked database credentials
- A consolidated target profile ready to support the next phase of the assessment (credential attacks, exploitation, and privilege escalation)